



Document Management SubSystem

- 1. Aliaa Khalil Abdullah Al_Dalali*
- 2. Lamees Nageeb Al_shameri*
- 3. Aya Fawaz Ahmed Qeran*
- 4. Nagham Al_masri*
- 5. Amani Al_alariqi*

Dr Mohammed Alqmase

Secure Software Engineering
Document management subsystem

Contents

1. Introduction.....	3
2. Problem Statement	4
3. System Objectives.....	5
4. Scope.....	6
Out of Scope:	7
Secure Requirements Gathering.....	8
Threat Modeling	14
(Scope-Break-Fix-Verify)	14
Threat Model	15
Scope	15
Information.....	15
Dependencies	16
Entry Points.....	17
Exit Points	19
Assets.....	20
Trust Levels	21
Data Flow Diagrams.....	22
Break.....	24
STRIDE Framework	24
Threat Analysis	26
Misuse Cases	28
Threat Description Table	30
Ranking	32
Probability x Impact (P x I) Ranking	34
Delphi Ranking.....	35
Average Ranking	36
Fix	37
Verify	45
Review Documentation:	45

Secure Software Engineering

1. Design and Architecture Documentation	45
3. Security Controls Documentation	45
Test Cases.....	48
T#001 – Unauthorized Case Access (IDOR).....	48
T#002 – Phishing via Fake Login Page.....	48
T#003 – Document Content Tampering.....	48
T#004 – Audit Log Tampering	48
T#005 – Confidential Document Leak.....	48
T#006 – DoS via Upload Flooding	49
T#007 – Stored XSS in Metadata.....	49
T#008 – Arbitrary Code Execution via Malicious File	49
T#009 – Privilege Escalation.....	49
T#010 – Metadata Forgery	49
T#011 – Malware in Uploaded Files.....	50
T#012 – Temporary Access Misuse	50
T#013 – Oversized File Upload	50
T#014 – Malicious Admin Retention Policy Change.....	50
T#015 – Misconfigured API Access.....	50
Validation.....	51
Backup	54
Final Notes	57
ER Diagrams	58
System Sequence Diagram:	66
Document management Interfaces	67

1. Introduction

The Document Management Subsystem (DMS) is a critical component of the Judicial Management System (JMS) in Yemen, responsible for handling all court-related documentation in a secure, reliable, and efficient manner. This subsystem plays a pivotal role in storing, retrieving, verifying, and securing legal documents across various stakeholders including judges, lawyers, litigants, prosecutors, and administrative staff.

Given the sensitive and legally binding nature of judicial documents, this subsystem must uphold confidentiality, integrity, availability, and non-repudiation throughout the document lifecycle. The DMS not only supports operational functionality like document uploads, versioning, and full-text search, but also integrates robust cybersecurity mechanisms such as role-based access control, encryption, secure transmission, malware scanning, and audit logging.

This document provides a cybersecurity expert's perspective on the security considerations, functional requirements, and implementation challenges associated with designing a secure and compliant Document Management Subsystem within JMS.

2. Problem Statement

Judicial institutions in Yemen are undergoing digital transformation to improve access to justice, streamline legal procedures, and enhance transparency. However, transitioning from a paper-based to a digital document handling system introduces significant cybersecurity risks. Legal documents often contain personally identifiable information (PII), evidence, and court decisions, which are prime targets for data breaches, unauthorized access, tampering, and cybercrime.

The absence of a properly secured document management subsystem can lead to:

1. Unauthorized access or leaks of confidential court records.
2. Tampering or falsification of digitally signed documents.
3. Inability to track user actions, raising concerns about accountability.
4. Data loss due to improper backup or recovery mechanisms.
5. Regulatory non-compliance with data protection laws.

To address these risks, there is a critical need for a secure, resilient, and auditable document management subsystem that aligns with secure software engineering principles, judicial privacy mandates, and modern cybersecurity standards.

3. System Objectives

The overarching goal of the Document Management Subsystem is to enable secure, efficient, and legally compliant handling of judicial documents throughout their lifecycle. Key objectives include:

1. Security & Privacy:

Ensure confidentiality, integrity, and availability of documents through strong encryption, role-based access control (RBAC), and compliance with local data protection regulations.

2. Authenticity & Non-Repudiation:

Enforce the use of digital signatures and tamper detection mechanisms to validate the source and integrity of all legal documents.

3. Auditability & Traceability:

Implement comprehensive audit logging for every document interaction (upload, download, view, modify, delete) to support legal accountability and forensic investigations.

4. Data Resilience:

Enable automated backups, disaster recovery, and secure data erasure mechanisms to ensure continuity and safe retirement of documents.

5. User-Centric Functionality:

Provide a user-friendly interface with support for document classification, versioning, OCR for scanned documents, full-text search, and notification systems.

6. Malware & Threat Detection:

Integrate automated malware scanning and file-type validation to prevent exploitation through malicious or unsupported document formats.

7. Access Governance:

Enforce multi-factor authentication (MFA) and strict access permissions based on user roles and document confidentiality levels.

4. Scope

This document addresses the security design and compliance aspects of the Document Management Subsystem within the Judicial Management System. The scope includes:

1. Functional Security Requirements:

Evaluation and implementation guidance on all 30 documented requirements — including encryption, signature verification, RBAC, MFA, malware scanning, versioning, and logging.

2. Security Threat Landscape:

Identification of potential attack vectors such as unauthorized access, insider threats, document tampering, and ransomware.

3. Integration Points:

Secure communication and data exchange with other JMS subsystems (e.g., Case Management, Prosecutor Portal) and external systems (e.g., National ID, Police, Legal Aid).

Secure Software Engineering
Document management subsystem

4. Compliance & Legal Framework:

Alignment with applicable data protection laws in Yemen, and judicial regulations on document retention, classification, and digital evidence handling.

5. Disaster Recovery & Data Resilience:

Analysis of business continuity requirements, including Recovery Time Objectives (RTOs) and secure document archival.

6. Usability & Administrative Control:

Ensuring that security mechanisms do not impede usability, and that system administrators retain fine-grained control over document policies and access rights.

Out of Scope:

1. UI/UX design not directly related to security.
2. Physical security of local data centers (addressed separately).
3. Non-document related features of JMS (e.g., courtroom scheduling, case status tracking).

Task01:

Secure Requirements Gathering

Secure Software Engineering

#	Requirements	Teacher Marks	
1	If a user attempts to upload a document that exceeds the size limit, The document management Sub system shall reject the upload and notify the user.		
2	If the verification of the e_signature fails, The document management Sub system shall alert the user and mark the document as unverified.		
3	The document management Sub system shall perform an automatic backup of all upload case related document every 48 hours.		
4	If a document is signed electronically, the document management Sub system shall verify the e_signature to ensure its integrity.		
5	The Document Management Sub-system shall encrypt all stored documents (Data at Rest) using strong and approved encryption algorithms to protect data confidentiality.		
6	The Document Management Sub-system shall encrypt all data in transit (Data in Transit) between the user and the system, and between internal components, using secure protocols such as TLS 1.2 or higher.		
7	The Document Management Sub-system shall enforce strict Role-Based Access Control (RBAC), where document viewing, modification, and deletion permissions are precisely defined based on the user's role (e.g., judge, lawyer, clerk).		

Secure Software Engineering

8	The Document Management Sub-system shall log all document-related activities (e.g., upload, view, modify, delete, sign, print) with a timestamp and user identifier for each action.		
9	The Document Management Sub-system shall provide an advanced search interface that allows searching documents using their content (full-text search) and metadata, while respecting user access permissions.		
10	The Document Management Sub-system shall support automatic document versioning, and shall allow authorized users to access and restore previous versions.		
11	The Document Management Sub-system shall scan all uploaded documents for malware or viruses before storage, and shall reject the storage of any infected documents.		
12	The Document Management Sub-system shall provide a strong Multi-Factor Authentication (MFA) mechanism for user logins, especially for users with sensitive privileges.		
13	If the number of failed login attempts exceeds a defined threshold, the Document Management Sub-system shall lock the user's account for a specified period or until manually unlocked.		
14	The Document Management Sub-system shall generate and store comprehensive audit logs securely and immutably to ensure non-repudiation of activities and enable forensic investigations.		

Secure Software Engineering

15	The Document Management Sub-system shall provide a function to define retention periods for judicial documents and shall automatically archive or delete them after the specified period, in accordance with judicial regulations.		
16	The Document Management Sub-system shall allow authorized users to temporarily and time-limited grant viewing or modification permissions for documents to their colleagues, with this change being recorded in the audit logs.		
17	The Document Management Sub-system shall reject the upload of documents that do not conform to predefined allowed formats, to prevent exploitation of file format-related vulnerabilities.		
18	The Document Management Sub-system shall support the use of certified digital signatures to ensure non-repudiation and authenticate the signer's identity.		
19	The Document Management Sub-system shall automatically send notifications to relevant users when the status of a document associated with their case changes or when a specific action is required on a document.		
20	The Document Management Sub-system shall ensure that all documents containing sensitive personal information are handled in compliance with applicable data protection and privacy laws in Yemen.		

Secure Software Engineering

21	The Document Management Sub-system shall be capable of detecting any attempts to modify documents after they have been electronically signed, and shall indicate if the document has been tampered with.		
22	The Document Management Sub-system shall provide a user-friendly interface for systematically classifying and tagging (metadata) documents to enhance searchability and security.		
23	The Document Management Sub-system shall enforce strong password policies (e.g., minimum length, complexity, expiration date) and shall compel users to change their passwords periodically.		
24	The Document Management Sub-system shall perform Optical Character Recognition (OCR) on scanned documents to convert images of text into searchable text while maintaining data security.		
25	The Document Management Sub-system shall support secure printing capabilities for documents, with the option to add watermarks or audit footers that prevent unauthorized reproduction or tampering.		
26	The Document Management Sub-system shall ensure the secure erasure of deleted documents and data from storage to prevent their unauthorized recovery (Secure Data Erasure).		
27	The Document Management Sub-system shall seamlessly integrate with the Judicial Case Management System to securely and automatically link each document to the correct case.		

Secure Software Engineering

28	The Document Management Sub-system shall provide a "Recycle Bin" feature for temporarily deleted documents, with a defined recovery period before final and secure deletion.		
29	The Document Management Sub-system shall allow users to define different confidentiality levels for documents (e.g., Top Secret, Secret, Public) and shall enforce different access permissions for each level.		
30	The Document Management Sub-system shall be able to successfully restore all documents and related data within a specified recovery time objective (RTO) following a disaster or major system failure.		

Task02:

Threat Modeling (Scope-Break-Fix-Verify)

Threat Model

In this document, we will provide a threat modeling about [Document Management subSystem].

Scope

In this section, we will break down our threat modeling phase [scope] in details as following

Information

APPLICATION NAME	Document Management subSystem
APPLICATION VERSION	V1.0
DESCRIPTION	The Document Management Subsystem is a core component of the Judicial Management System (JMS) designed to securely manage, store, retrieve, and process all types of judicial documents. This includes case files, pleadings, evidence, motions, orders, and judgments throughout their lifecycle, ensuring data integrity, confidentiality, and availability for authorized users within the Yemeni judicial system. It handles document uploads, versioning, access control, secure storage, and archiving.
DOCUMENT OWNER	1. Aliaa Khalil Abdullah Al_Dalali 2. Lamees Nageeb Al_shameri 3. Aya Fawaz Ahmed Qeran 4. Nagham Al_masri 5. Amani Al_alariqi
PARTICIPANTS	1. System Developers 2. Legal Advisors 3. End Users
REVIEWER	MR. Mohammed Alqmase

Dependencies

ID	EXTERNAL DEPENDENCIES DESCRIPTION
1	Operating System (OS) and Underlying Infrastructure: The Document Management Subsystem relies heavily on the security and stability of the underlying operating system (e.g., Linux, Windows Server) and virtualized/physical hardware infrastructure. Vulnerabilities or misconfigurations in the OS or infrastructure can directly impact the security (confidentiality, integrity, availability) of stored judicial documents.
2	Database Management System (DBMS): The subsystem depends on a secure and robust DBMS (e.g., PostgreSQL, Oracle, SQL Server) for storing document metadata, access control lists, audit logs, and potentially the documents themselves. Security flaws or unpatched vulnerabilities in the DBMS can lead to unauthorized access, data tampering, or information disclosure of sensitive judicial records
3	Identity and Access Management (IAM) System / Directory Service: The Document Management subsystem relies on an external IAM system (e.g., Active Directory, LDAP, or a centralized user management system for JMS) for user authentication and authorization. Any compromise or misconfiguration in this system would directly impact who can access and manage judicial documents.
4	Network Infrastructure & Services: The subsystem depends on the underlying network (routers, firewalls, switches, DNS, NTP) to provide secure and reliable communication channels for document transfer and access. Network vulnerabilities, misconfigurations, or attacks (e.g., MITM, DoS) can compromise the confidentiality and availability of documents

Entry Points

ID	NAME	DESCRIPTION	TRUST LEVELS
1	Application Programming Interface (API) for Inter-Communication Subsystem	A set of programmatic interfaces used by other components of the Judicial Management System (JMS), such as Case Filing, Workflow Management, or Reporting Subsystems, to interact with the Document Management Subsystem (e.g., to file new documents, retrieve case-related documents).	System-to-System, Medium-to-High (Requires strong mutual authentication and authorization between subsystems. Trust is higher than external human users but still requires robust controls due to automated access and potential for large data transfers.)
2	Web Application User Interface (UI)	The primary graphical interface through which authorized users (e.g., judges, court clerks, lawyers, litigants) access, upload, view, modify, and search judicial documents. This is the most common and extensive entry point for human interaction.	Authenticated, Low-to-High (Depends on user role and data sensitivity. Initial trust is low until strong authentication and authorization are performed. Trust level escalates based on privileges for specific document types/actions.)
3	Secure File Upload/Ingestion Gateway	A dedicated entry point for secure ingestion of external documents, potentially from external sources (e.g., law firms, police departments) or bulk uploads. This might involve a secure file transfer protocol or a specific portal	External-to-System, Low (Initially very low trust. Requires rigorous input validation, malware scanning, and content verification before documents are accepted and processed into the core system. Authentication of external entities is crucial.)

Secure Software Engineering

4	Administrative Interface/Backend Access	A specialized interface, often command-line or a separate web portal, used by system administrators or security personnel to manage the Document Management Subsystem itself (e.g., user management, configuration, database access, backup/restore operations).	Highly Trusted, Extremely Sensitive (Reserved for a very limited number of highly privileged users. Requires the strongest authentication (MFA, perhaps physical tokens), strict access controls, extensive logging, and continuous monitoring due to the potential for critical system compromise.)
---	---	--	--

Exit Points

ID	NAME	DESCRIPTION	TRUST LEVELS
1	Document Download/Export Interface	Allows authorized users (e.g., judges, lawyers, litigants) to download or export judicial documents from the system for offline access, printing, or submission to external non-integrated parties.	Authenticated User, Low-to-Medium Trust for Output (While the user is authenticated, the output itself carries risk. Data must be securely transmitted and protected from tampering or interception during download. Trust is on the receiving end's handling.)
2	Reporting and Analytics Output	The subsystem may generate reports containing aggregated data or summaries derived from judicial documents (e.g., case statistics, caseload reports). These reports might be sent to external governmental bodies, auditing entities, or for public statistical release	System-to-External Entity. Medium (Reports may contain anonymized or aggregated data, but this 24/6 accuracy is critical. Transmission channels and masking/anonymization techniques are required to prevent information disclosure.)
3	API for Inter-Subsystem Data Transfer (e.g., to Archival, Printing Subsystems)	Data or documents are programmatically transferred from the Document Management Subsystem to other integrated JMS subsystems, such as a long-term archival system, an external printing service for hard copies, or a specialized data analysis module.	System-to-System, Medium-to-High (Requires strong mutual authentication and secure communication channels (e.g., encrypted APIs) to maintain the confidentiality and integrity of documents as they transition to other trusted internal systems. Trust is based on the security of the receiving subsystem.)
4	Audit Log and Alerting System Integration	Security-relevant events (e.g., unauthorized access attempts, document modifications) generated by the Document Management Subsystem are forwarded to a centralized security information and event management (SIEM) system or an alerting system	System-to-Security System, High (This is a critical exit point for security monitoring. The integrity and confidentiality of these logs are paramount to enable effective threat detection and incident response. Trust is high.)

Assets

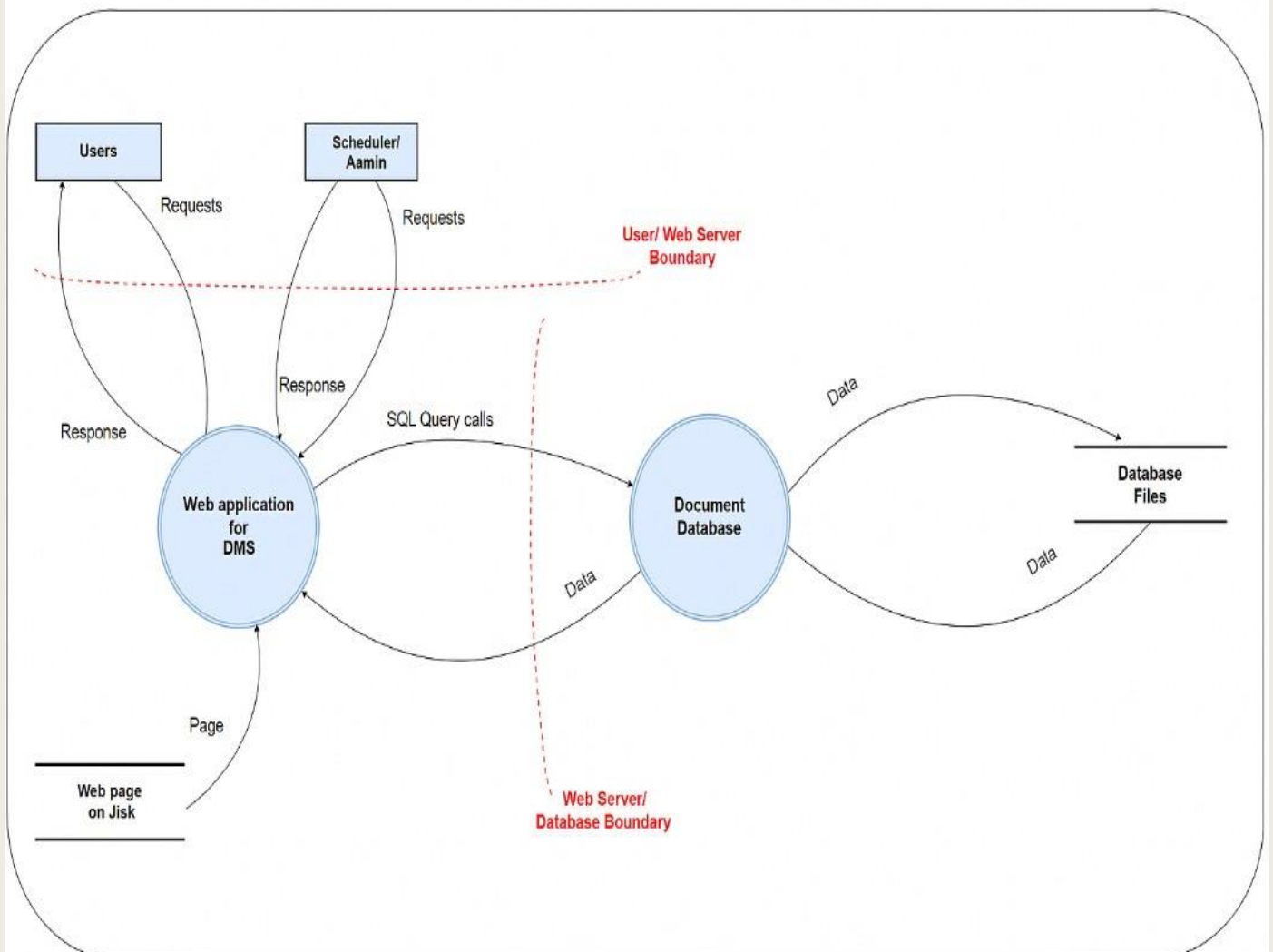
ID	NAME	DESCRIPTION	TRUST LEVELS
1	Judicial Documents (Content)	The actual electronic files and their content (e.g., case pleadings, evidence, judgments, decrees, confidential reports). This is the primary and most sensitive asset, whose confidentiality, integrity, and availability are paramount for justice administration.	Extremely High Sensitivity/Critical Trust (Compromise leads to severe legal, financial, and reputational damage. Requires the highest level of protection.)
2	Document Metadata and Indexing information	Data associated with each document, such as case ID, document type, filing date, author, parties involved, access Permissions and search indexes. This metadata is crucial for document retrieval, management, and enforcing access controls	High Sensitivity/High Trust (Compromise can lead to unauthorized access to documents, misfiling, loss of Search capability, or manipulation of case information, indirectly affects judicial outcomes
3	User Credentials and Access Rights	Information pertaining to user identities, authentication data (e.g., hashed passwords, MFA tokens), and their assigned roles and permissions within the Document Management Subsystem. This asset controls who can access what	Extremely High Sensitivity/Critical Trust (Compromise of credentials or access rights can lead to a complete system takeover, unauthorized access to all documents, or widespread data manipulation.)
4	Audit logs and security event data	Immutable records of all activities performed within the Document Management Subsystem, including document access, modifications, deletions, and security-relevant events (e.g., failed login attempts, policy violations). Essential for accountability, forensics, and threat detection	High Sensitivity & High Integrity Requirement/High Trust (Compromise (tampering or deletion) undermines accountability, prevents detection of breaches, and hinders forensic investigations, making it a prime target for attackers.)

Trust Levels

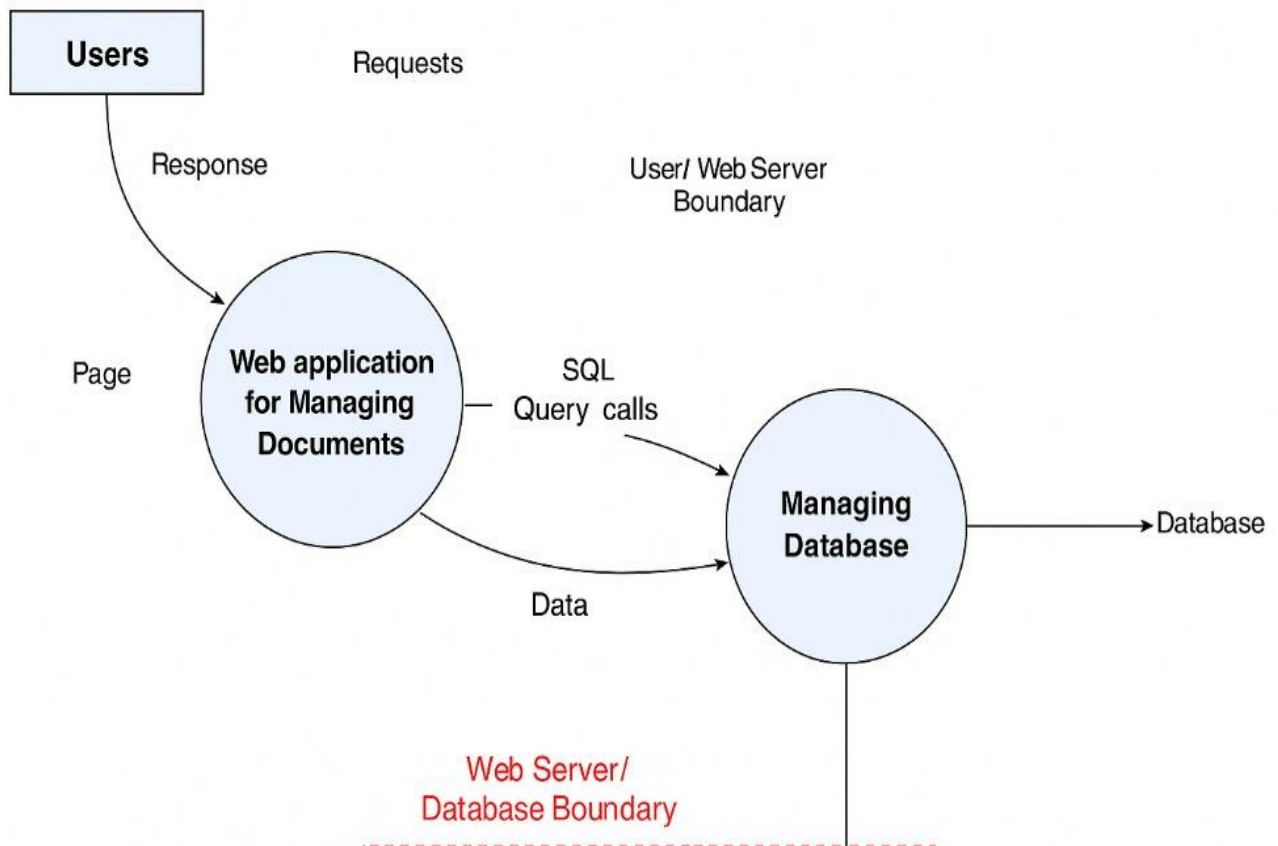
ID	NAME	DESCRIPTION
1	Highly Privileged/Administrative Trust	This level applies to entities (e.g., System Administrators, CISO, Lead Developers) with the highest level of access and control over the Document Management Subsystem, including system configuration, user management, security settings, and direct access to raw data. Their actions can significantly impact the system's security and the integrity/confidentiality of all judicial documents. Requires the strongest authentication and continuous monitoring.
2	Authenticated Judicial Personnel Trust	This level applies to authorized judicial staff (e.g., Judges, Court Clerks, Prosecutors, Authorized Lawyers) who have been successfully authenticated and are granted access based on their specific roles and the principle of least privilege. They can create, view, modify, and delete documents relevant to their assigned cases or duties within the system. The Trust is contingent on strong authentication and strict adherence to RBAC.
3	Integrated System/API Trust	This level applies to other trusted subsystems within the broader Judicial Management System (JMS) that interact with the Document Management Subsystem via secure APIs (e.g., Case Filing Subsystem, Workflow Engine, Archival System). Trust is established through mutual authentication, secure communication protocols, and predefined permissions for automated data exchange. Trust depends on the security posture and integrity of the integrated system.
4	External/LoW Trust	This level applies to entities or sources outside the immediate trusted network of the JMS, such as public users accessing specific non-confidential documents, external file submission portals, or unverified data feeds. Access is highly restricted, limited to publicly available or pre-approved information, and subject to rigorous security checks (e.g., malware scanning, input validation) before any data is processed. Initial trust is minimal to non-existent

Data Flow Diagrams

Data Flow Diagram :
Document Management System



Data Flow Diagram : Document Management System



Break

In this section, we will deconstruct the Document Management Subsystem to identify potential security weaknesses and categorize threats using established frameworks, providing a structured approach to threat identification.

STRIDE Framework

This table details specific threats against the Document Management Subsystem using the STRIDE threat model, outlining what an attacker may be able to achieve and the corresponding security control types.

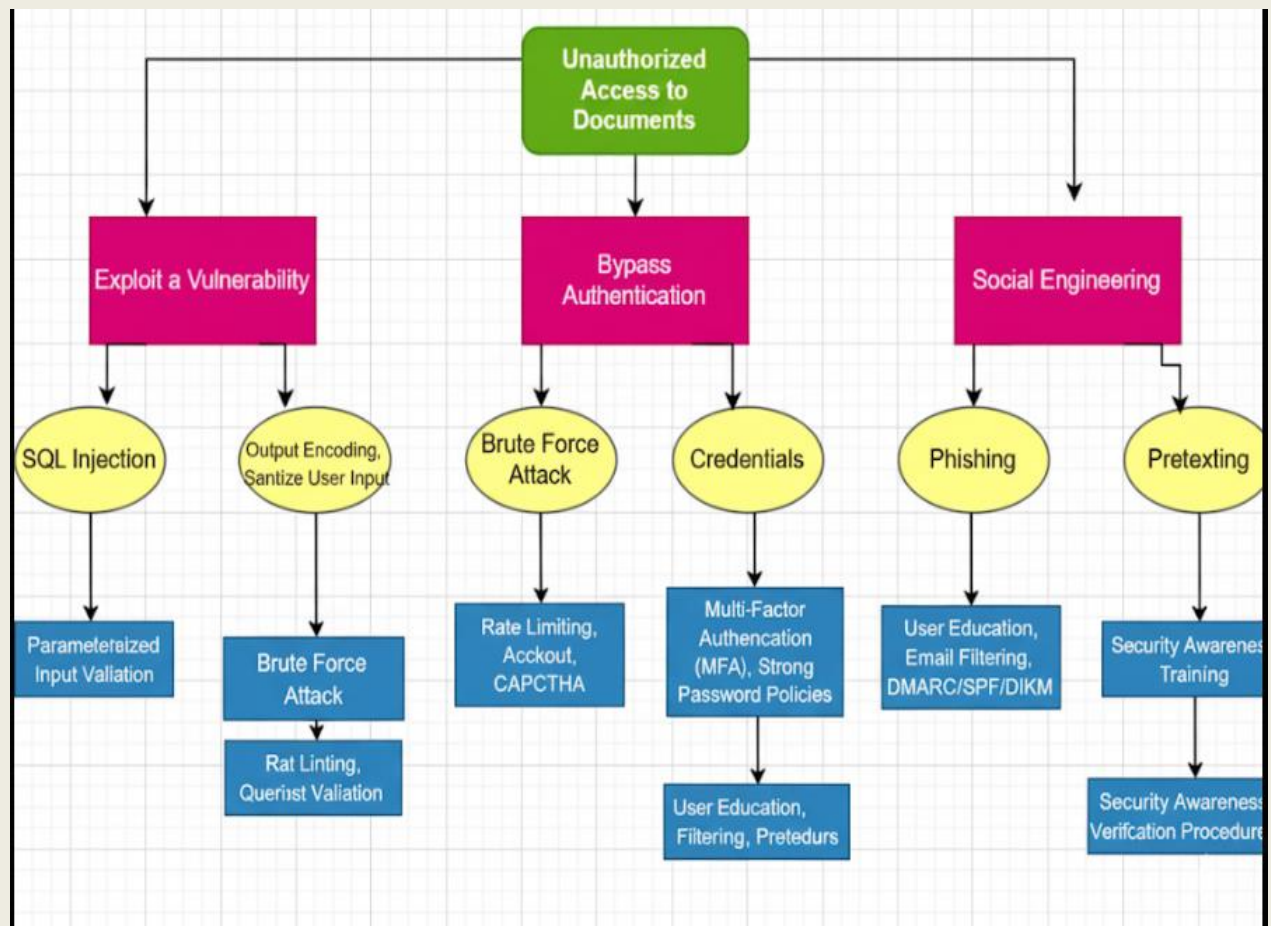
STRIDE Framework

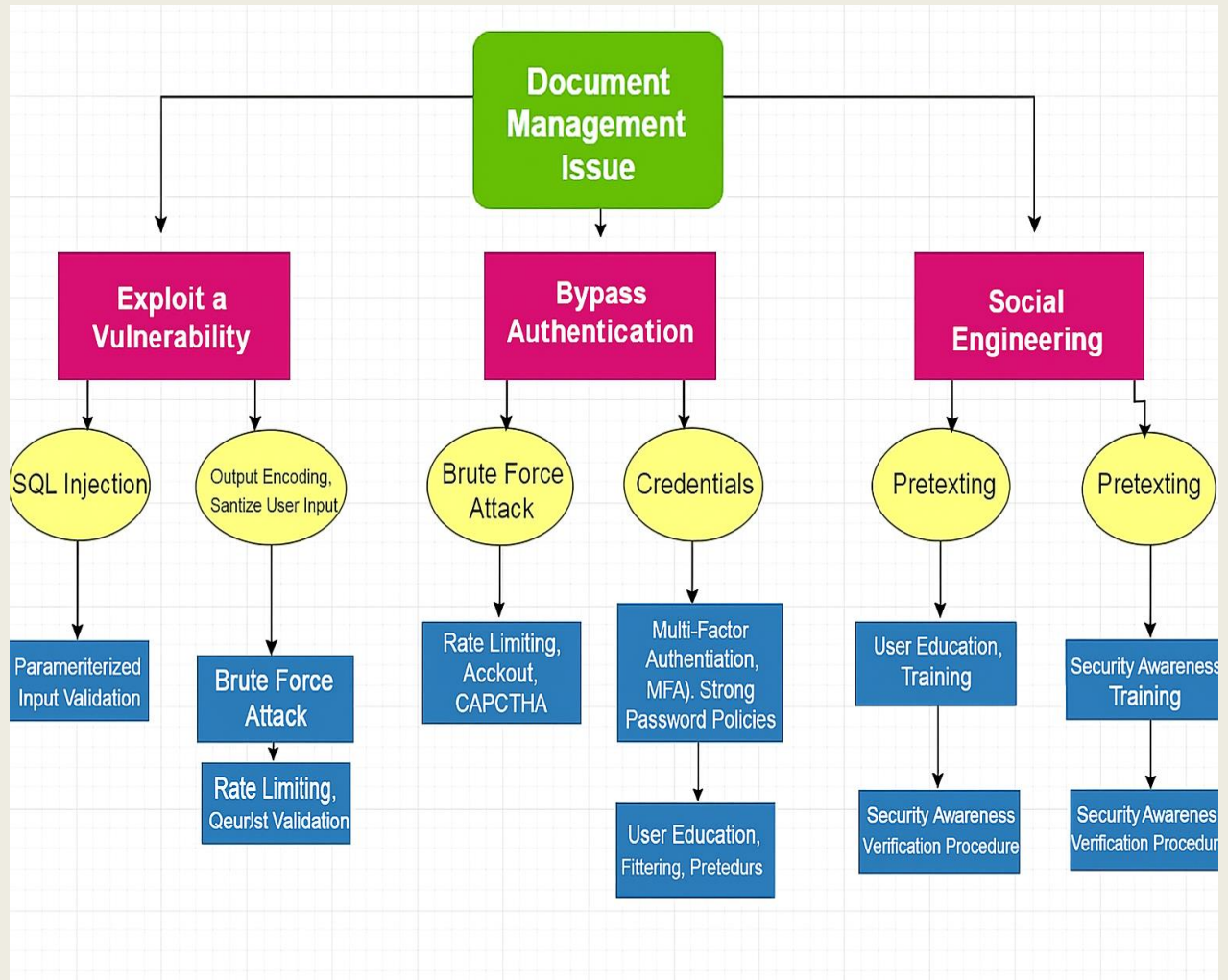
ID	THREATS TYPES	THREATS DESCRIPTION	SECURITY CONTROL TYPES
1	Spoofing	1. An attacker may be able to 2. Impersonate an authorized user (e.g., judge, clerk) to access, upload, or modify judicial documents. 3. Impersonate a trusted system component (e.g., API endpoint, document server) to receive/send forged data or intercept communications.	Authentication
2	Tampering	1. Modify the content of sensitive judicial documents (e.g., judgments, evidence) stored in the system without authorization. 2. Alter document metadata (e.g., dates, authors, status) to change document context or hide malicious activities. 3. Manipulate audit logs to conceal evidence of unauthorized access or modifications.	Integrity
3	Repudiation	1. Deny having performed an action (e.g., approving a judgment, uploading a document) that was, in fact, performed.	Non-repudiation

Secure Software Engineering

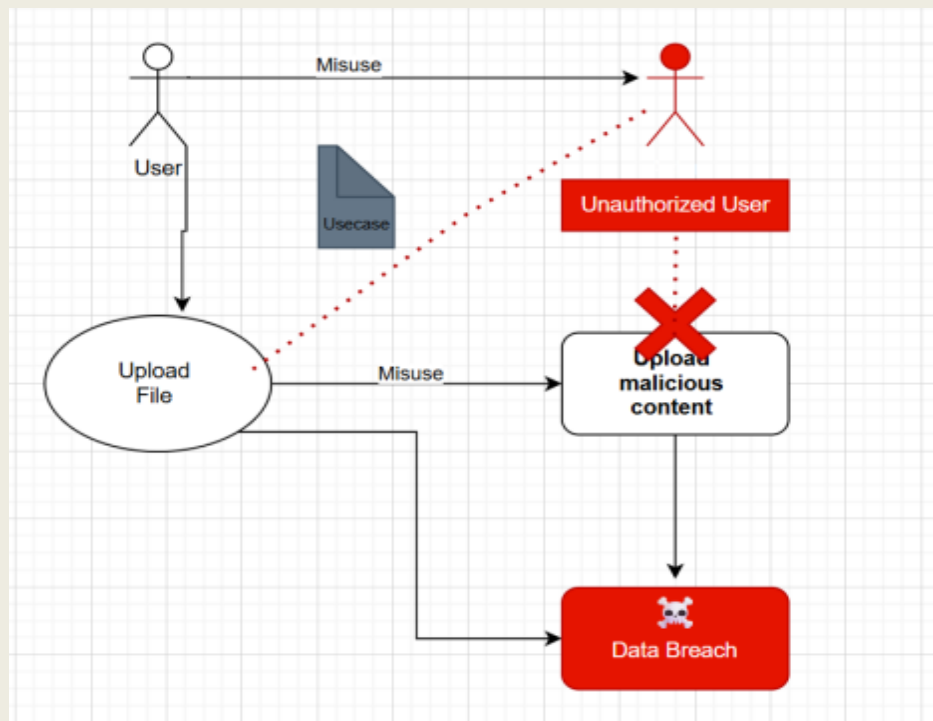
		2. Claim not to have received a critical document or notification from the system despite evidence of delivery. 3. Deny responsibility for changes made to documents or system configurations..	
4	Information Disclosure	1. Access confidential judicial documents (e.g., private case details, witness statements) without proper authorization. 2. Exfiltrate sensitive personal data (e.g., PII of litigants) from the Document Management Subsystem. 3. Gain access to system configuration details or database schemas that could aid further attacks.	Confidentiality.
5	Denial of Service	1. Prevent authorized users from accessing or uploading judicial documents, halting critical court operations. 2. Overload the document storage or retrieval mechanisms, rendering the subsystem unresponsive. 3. Corrupt or encrypt documents, making them unavailable for legitimate use.	Availability
6	Elevation of Privileges	1. Gain higher access rights (e.g., from a regular user to an administrator) within the Document Management Subsystem. 2. Access functionalities or documents typically reserved for more privileged roles (e.g., modifying system-wide settings, viewing highly classified documents). 3. Bypass existing access control mechanisms to perform unauthorized actions	Authorization

Threat Analysis

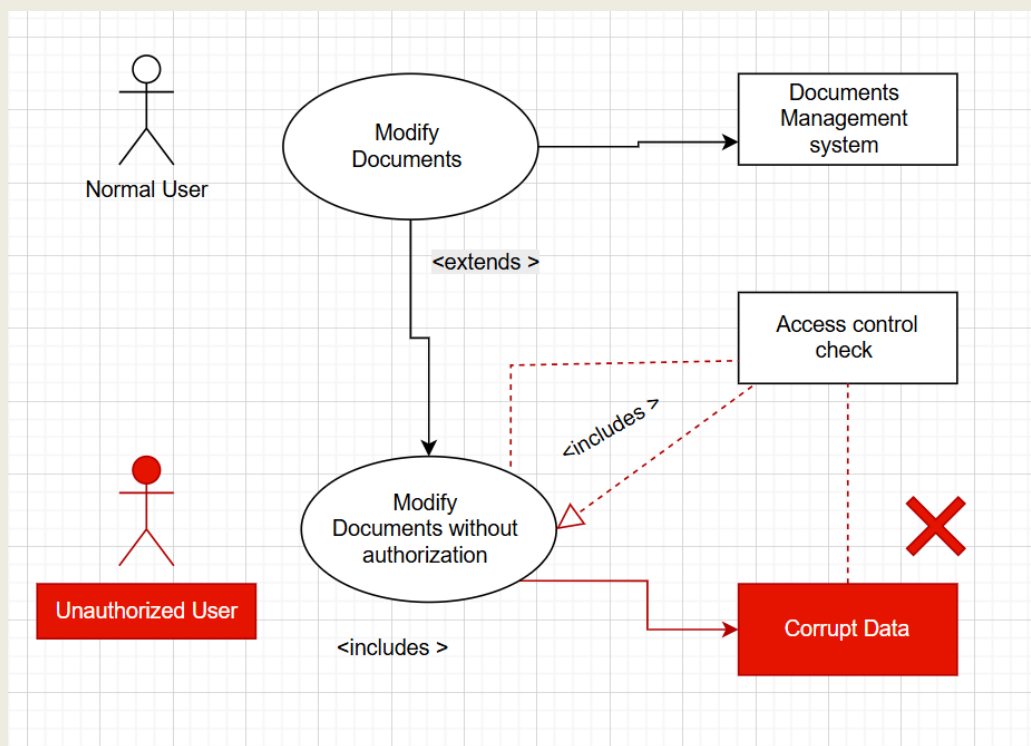
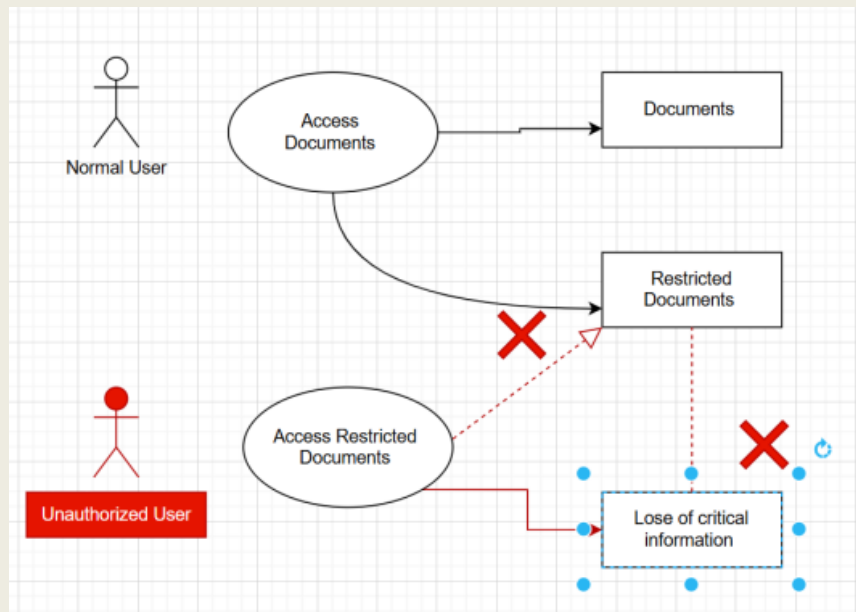




Misuse Cases



Secure Software Engineering



Threat Description Table

THREAT ID	THREAT DESCRIPTION	THREATS TYPES	Name of student
1	A malicious user, such as a hacker or insider, impersonates an authorized user (e.g., a judge or a lawyer) to gain unauthorized access to confidential judicial documents.	Spoofing	Aliaa
2	An attacker creates a fake login page that mimics the Document Management Subsystem's interface to deceive users into providing their credentials, allowing the attacker to steal them.	Spoofing	- Aliaa
3	An unauthorized party modifies the content of a judicial document (e.g., changing a court ruling or witness testimony) after it has been uploaded to the system.	Tampering	Aliaa
4	An attacker deletes or alters the system's audit logs to erase the evidence of their malicious activities, such as unauthorized access or data modification.	Tampering	Aya
5	An attacker gains unauthorized access to the system and steals or leaks confidential case documents, such as personal information of litigants or sealed court records.	Information Disclosur	Aya
6	An attacker floods the Document Management Subsystem with an excessive number of upload requests or other resource-intensive operations, overloading the system and preventing legitimate users from accessing or managing documents.	Denial of Service	Aya
7	An attacker uploads a document containing malicious scripts (e.g., JavaScript or HTML) which, when viewed by another user, executes and steals their session credentials.	Injection	Nagham
8	An attacker exploits a vulnerability in the system's file parser to execute arbitrary code by crafting a malicious document that crashes the application and grants them control.	Arbitrary code Execution	Nagham

Secure Software Engineering

9	An internal actor, with authorized access to some documents, exploits a system flaw to bypass access controls and access documents they are not authorized to view.	Elevation of privilege	Nagham
10	An attacker sends a forged document to the system with a fake metadata stamp (e.g., date, author) to misrepresent its authenticity and origin.	Information Disclosur	Lamees
11	A malicious actor intercepts unencrypted communication between a user's device and the DMS, capturing sensitive case documents or authentication tokens during transmission.	Information Disclosure	Lamees
12	A user with temporary access to a sensitive document (e.g., a clerk) fails to have their access automatically revoked after the allowed time period expires, resulting in extended unauthorized access.	Elevation of Privilege	Lamees
13	An attacker uploads an oversized or unsupported file format to exploit the document processing system, causing a crash or triggering denial of service.	Denial of Service	Amani
14	A disgruntled employee with administrative privileges intentionally alters document retention policies to prematurely delete critical legal records.	Tampering	Amani
15	An attacker exploits a misconfigured API endpoint used for integration with external systems (e.g., Prosecutor's Portal), gaining access to documents without proper authentication.	Spoofing / Elevation of Privilege	Amani

Ranking

- **Prioritizing User Impersonation:** This is a top-ranked threat because a successful impersonation can lead to a complete compromise of the system's confidentiality and integrity. The solution is to implement Continuous Behavior Monitoring that flags and alerts administrators when an authorized user's actions deviate from their normal behavior, such as accessing a large number of files outside of business hours or from an unusual location.
- **Mitigating Document Tampering:** Given the critical impact of document tampering on legal proceedings, the solution is to enforce Strict Document Integrity Checks. The system should use cryptographic hashing to create a unique fingerprint of each document. This hash is then securely stored and regularly reverified to immediately detect any unauthorized changes to the document's content.
- **Handling Information Disclosure:** This threat is a major concern due to the sensitive nature of
- **The nature of judicial data.** A key solution is Automated Metadata Scrubbing. Before a document is made publicly available or shared outside the system, the platform will automatically remove all hidden metadata, such as author names, creation dates, or geolocation, from images to prevent accidental information leaks.
- **Preventing Privilege Escalation:** This threat is highly dangerous as it allows a user to gain unauthorized administrative control. The solution is to apply the Principle of Least Privilege (PoLP) with Just-in-Time (JIT) access. Users are granted only the minimum permissions required for their specific task, and any elevated privileges (e.g., access to a sealed document) are temporary and automatically revoked after the task is completed.
- **Securing Against System Impersonation:** To combat phishing and system spoofing, the solution is to implement a visual or multifactor authentication

indicator. The system's login page will display a unique, user-selected image or phrase that only appears on the legitimate site, training users to recognize fake sites that lack this security marker

- **Combating Malware Injection:** This threat can lead to data corruption or theft. The solution is to deploy an API-based file sandboxing service. When a new document is uploaded, the system does not store it immediately. Instead, it sends the file to a secure, isolated environment where it is "executed" to check for malicious behavior before being securely stored.
- **Addressing Denial of Service (DoS):** To maintain system availability, the solution is to place a Web Application Firewall (WAF) in front of the system. This WAF will monitor incoming traffic, identify, and block malicious requests that could overwhelm the server, while allowing legitimate user traffic to pass through unimpeded.
- **Ensuring Audit Log Integrity:** The integrity of audit logs is crucial for accountability and forensic investigations. The solution is to implement Immutable Audit Logging. All system actions are recorded in a centralized, append-only log that uses write-once storage, making it impossible for an attacker—even one with high privileges—to delete or alter the log entries
- **Protecting Data at Rest and in Transit:** To prevent information disclosure, all data must be encrypted. The solution is to use end-to-end encryption. This means documents are encrypted at the user's device before being sent and remain encrypted while in transit and when stored on the server.
- **Ensuring Business Continuity:** To counter the threat of data loss, the solution is a comprehensive Geo-Redundant Disaster Recovery Plan. The system will not only perform regular backups but will also replicate all data and system configurations to a geographically distinct backup data center.

Probability x Impact (P x I) Ranking

THREAT ID	THREAT TITLE	P (Probability)	I (Impact)	RISK SCORE (P × I)	RANK
1	User Impersonation (Judge/Lawyer)	4	5	20	3
2	Credential Phishing (Fake Login Page)	4	4	16	6
3	Document Content Tampering	4	5	20	3
4	Audit Log Manipulation	3	5	15	8
5	Confidential Document Leak	5	5	25	1
6	DDoS – Upload Flood	4	4	16	6
7	Script Injection via Document (XSS)	3	4	12	11
8	Malicious Document → Code Execution	3	5	15	8
9	Internal Privilege Escalation	4	5	20	3
10	Fake Document Metadata Submission	4	4	16	6
11	Data Interception (MITM)	3	4	12	11
12	Expired Temporary Access Not Revoked	3	4	12	11
13	Oversized File Crash	3	3	9	13
14	Malicious Admin Alters Retention Rules	2	5	10	12
15	Exploit via Misconfigured API	4	5	20	3

Secure Software Engineering

Delphi Ranking

THREAT ID	THREAT TITLE	Aliaa	Lamees	Aya	Nagham	Amani	AVERAGE RANK	FINAL CONSENSUS RANK
1	User Impersonation	1	1	2	2	1	1.4	Critical
2	Credential Phishing	2	2	2	1	2	1.8	Severe
3	Document Content Tampering	1	1	1	2	2	1.4	Critical
4	Audit Log Manipulation	2	2	1	2	2	1.8	Severe
5	Confidential Document Leak	1	1	1	1	1	1.0	Critical
6	DDoS / Resource Exhaustion	2	3	2	2	3	2.4	Severe
7	Script Injection via Document	2	2	2	3	2	2.2	Severe
8	Malicious Code Execution	1	2	2	2	2	1.8	Severe
9	Internal Privilege Escalation	1	1	2	1	1	1.2	Critical
10	Fake Document Metadata	2	2	2	3	2	2.2	Severe

Secure Software Engineering

11	Data Interception (MITM)	2	2	3	2	2	2.2	Severe
12	Expired Access Not Revoked	2	3	3	2	3	2.6	Minimal
13	Oversized File → Crash	3	3	3	3	3	3.0	Minimal
14	Malicious Admin Alters Retention	2	1	2	2	1	1.6	Critical
15	Exploit via Misconfigured API	1	1	2	1	2	1.4	Critical

Average Ranking

THREAT ID	THREAT TITLE	D	R	E	A	AVERAGE RANK	RISK LEVELS
1	User Impersonation	3	3	3	3	3.0	High
2	Credential Phishing	3	3	3	2	2.75	High
3	Document Content Tampering	3	3	3	2	2.75	High
4	Audit Log Manipulation	3	2	3	2	2.5	High
5	Confidential Document Leak	3	3	3	3	3.0	High
6	DDoS / Resource Exhaustion	2	3	3	3	2.75	High
7	Script Injection via Document	2	3	2	3	2.5	High
8	Malicious Code Execution	2	3	2	3	2.5	High

Secure Software Engineering

9	Internal Privilege Escalation	3	3	3	3	3.0	High
10	Fake Document Metadata	2	2	2	2	2.0	Medium
11	Data Interception (MITM)	2	3	3	3	2.75	High
12	Expired Access Not Revoked	2	2	2	2	2.0	Medium
13	Oversized File → Crash	1	2	2	1	1.5	Low
14	Malicious Admin Alters Retention	3	3	3	3	3.0	High
15	Exploit via Misconfigured API	3	3	3	3	3.0	High

Fix

Threat Id: T#001

Threat	Unauthorized Case Access
Threat Description	Exploiting Weak Authentication To Access Restricted Case Records.
Threat Targets	1. Authentication System 2. Session Management
Attack Techniques	1. Session Hijacking 2. Credential Stuffing 3. Cookie Tampering
Security Impact	1. Privacy Breach 2. Data Tampering
Risk	High
Safeguard Controls To Implement	1. Multi-Factor Authentication (Mfa) 2. Role-Based Access Control (Rbac) 3. Session Monitoring

Threat Id: T#002

Threat	Credential Phishing (Fake Login Page)
Threat Description	Attackers Clone The Login Page To Steal User Credentials.
Threat Targets	1. Login Interface 2. User Trust
Attack Techniques	1. Phishing Emails 2. Fake Domains 3. Social Engineering
Security Impact	1. Unauthorized Access 2. Credential Compromise
Risk	High
Safeguard Controls To Implement	1. Mfa 2. Domain Monitoring 3. Anti-Phishing Training And Alerts

Threat Id: T#003

Threat	Document Content Tampering
Threat Description	Modification Of Uploaded Documents Without Detection.
Threat Targets	1. Document Storage 2. Integrity Controls
Attack Techniques	1. Metadata Manipulation 2. Direct File Modification
Security Impact	1. Evidence Compromise 2. Judicial Process Manipulation
Risk	High
Safeguard Controls To Implement	1. Digital Signatures 2. Hash Verification 3. Document Versioning

Threat Id: T#004

Threat	Audit Log Manipulation
Threat Description	Attackers Alter Or Delete Logs To Hide Malicious Activity.
Threat Targets	1. Audit Logging System 2. System Logs
Attack Techniques	1. Log File Tampering 2. Log Deletion Via Privilege Misuse
Security Impact	1. Loss Of Accountability 2. Obstructed Forensics
Risk	High
Safeguard Controls To Implement	1. Immutable Logging 2. Log Access Control 3. External Log Replication

Threat Id: T#005

Threat	Confidential Document Leak
Threat Description	Sensitive Case Files Are Accessed Or Leaked To Unauthorized Parties.
Threat Targets	1. Document Storage 2. Api Access
Attack Techniques	1. Insider Access Misuse 2. External Breach
Security Impact	1. Privacy Breach 2. Legal Ramifications
Risk	Critical
Safeguard Controls To Implement	1. Encryption (At Rest & Transit) 2. Access Control Lists 3. Monitoring And Alerting

Threat Id: T#006

Threat	Ddos Via File Upload Flooding
Threat Description	System Is Flooded With Uploads To Cause Denial Of Service.
Threat Targets	1. File Upload Handler 2. Storage Resources
Attack Techniques	1. Botnet Uploads 2. Oversized File Submissions
Security Impact	1. Service Unavailability 2. Delayed Operations
Risk	High
Safeguard Controls To Implement	1. File Size Limits 2. Rate Limiting 3. Upload Queuing

Threat Id: T#007

Threat	Script Injection Via Document
Threat Description	Documents Contain Scripts That Execute In The User's Browser.
Threat Targets	1. Document Viewer 2. Web Interface
Attack Techniques	1. Embedded Javascript 2. Html Injection
Security Impact	1. Credential Theft 2. Session Hijacking
Risk	High
Safeguard Controls To Implement	1. Input Sanitization 2. Disable Script Execution 3. Security Scanning Of Uploads

Threat Id: T#008

Threat	Malicious File Execution
Threat Description	Crafted Files Exploit Parser Vulnerabilities To Execute Code.
Threat Targets	1. File Parser 2. Server Backend
Attack Techniques	1. Buffer Overflows 2. Exploit-Laden Documents
Security Impact	1. Remote Code Execution 2. System Compromise
Risk	High
Safeguard Controls To Implement	1. File Format Validation 2. Antivirus Scanning 3. Sandbox Processing

Threat Id: T#009

Threat	Internal Privilege Escalation
Threat Description	Users Exploit Logic Flaws To Escalate Privileges.
Threat Targets	1. Role-Based Access System 2. Api Permissions
Attack Techniques	1. Bypassing Access Checks 2. Forced Browsing
Security Impact	1. Unauthorized Document Access 2. Policy Violation
Risk	High
Safeguard Controls To Implement	1. Strict Rbac Validation 2. Access Logging 3. Penetration Testing

Threat Id: T#010

Threat	Fake Document Metadata
Threat Description	Attackers Forge Metadata To Misrepresent A Document's Origin Or Timing.
Threat Targets	1. Metadata Parser 2. Case History Logs
Attack Techniques	1. Metadata Spoofing 2. Timestamp Alteration
Security Impact	1. Judicial Fraud 2. Misleading Evidence
Risk	Medium
Safeguard Controls To Implement	1. Trusted Timestamping 2. Metadata Validation 3. Chain-Of-Custody Logging

Threat Id: T#011

Threat	Data Interception In Transit
Threat Description	Sensitive Data Is Intercepted During Transmission.
Threat Targets	1. Network Traffic 2. Tls Sessions
Attack Techniques	1. Mitm Attacks 2. Packet Sniffing
Security Impact	1. Data Leak 2. Session Hijacking
Risk	High
Safeguard Controls To Implement	1. Enforce Tls 1.2+ 2. Certificate Pinning 3. Vpn For Internal Systems

Threat Id: T#012

Threat	Expired Temporary Access Not Revoked
Threat Description	Temporary Document Access Remains Active Past Its Intended Expiry.
Threat Targets	1. Permission System 2. User Sessions
Attack Techniques	1. Expiry Bypass 2. Forgotten Access Revocation
Security Impact	1. Prolonged Unauthorized Access 2. Policy Non-Compliance
Risk	Medium

Threat Id: T#013

Threat	Oversized File Attack (Crash / Resource Drain)
Threat Description	Malicious Uploads Of Very Large Or Corrupt Files Intended To Exhaust System Resources Or Crash The Document Processing Service.
Threat Targets	1. File Upload Handler 2. Backend Processing Services
Attack Techniques	1. Oversized Files 2. Zip Bomb 3. Memory Exhaustion
Security Impact	1. System Crash 2. Denial Of Service
Risk	Low
Safeguard Controls To Implement	1. File Size Limits 2. Content-Type Validation 3. Sandboxed Document Parsing

Threat Id: T#014

Threat	Malicious Admin Alters Retention Rules
Threat Description	A Privileged User Maliciously Changes Document Retention Policies To Delete Or Hide Sensitive Or Incriminating Records.
Threat Targets	1. Retention Policy Configuration 2. Admin Control Panel
Attack Techniques	1. Policy Tampering 2. Unauthorized Deletions
Security Impact	1. Loss Of Legal Documents 2. Obstruction Of Justice
Risk	High
Safeguard Controls To Implement	1. Segregation Of Duties (Sod) 2. Approval Workflow For Policy Changes 3. Immutable Backup/Archive Systems

Threat Id: T#015

Threat	Exploit Via Misconfigured Api
Threat Description	Public Or Internal Apis With Weak Configurations Or Missing Authorization Controls Are Exploited To Access Or Modify Case Documents.
Threat Targets	1. Document Api Endpoints 2. Api Gateway
Attack Techniques	1. Idor (Insecure Direct Object Reference) 2. Missing Auth Checks 3. Unfiltered Input
Security Impact	1. Unauthorized Data Access 2. Data Tampering
Risk	High
Safeguard Controls To Implement	1. Api Authentication & Authorization 2. Input Validation 3. Security Testing (Api Fuzzing & Sast)

Verify

Review Documentation:

1. Design and Architecture Documentation

- Verify that Use Case Diagrams, Data Flow Diagrams (DFDs), and Document Lifecycle Workflows accurately reflect the updated DMS architecture, particularly for:
 - Document upload/download pipelines
 - E-signature verification processes
 - Malware scanning and secure storage
- Ensure that entry points (e.g., upload forms, APIs), exit points (e.g., download, export, print), and trust boundaries are clearly marked and described.
- Confirm that threat surfaces such as the File Upload Interface, Metadata Processors, and Role-Based Viewers are identified and matched to controls.

2. Access Control Documentation

- Review the Role-Based Access Control (RBAC) matrix to ensure:
 - Each role (Judge, Lawyer, Clerk, Administrator, Litigant, Prosecutor) is restricted to the minimum necessary permissions.
 - Temporary and shared access complies with time-bound access policies (related to Threat T#012).
- Confirm documentation includes:
 - Multi-Factor Authentication (MFA) requirements for privileged roles.
 - Access-level separation for sensitive documents (Top Secret, Secret, Public).
 - Proper controls for elevation of privilege mitigation (T#009)

3. Security Controls Documentation

- Confirm that each threat (T#001–T#015) in the STRIDE threat model has one or more documented, mapped security controls, including:
 - Encryption at rest and in transit (T#005, T#011)
 - File validation and format whitelisting (T#013, T#017)
 - Digital signature verification and anti-tampering checks (T#003, T#021)
 - Audit log protection and immutability (T#004, T#014)
- Validate implementation of:
 - Prepared statements and input sanitization for any metadata fields.
 - CSRF/XSS/XSSI protections in the document viewer interface.
 - Virus/malware scanning prior to storage (T#011).

4. Operational and Maintenance Procedures

- Confirm documentation includes:
 - Backup frequency (every 48 hours) and backup encryption for secure recovery (T#030).
 - Patch management policies for backend libraries and document parsers.
 - Firewall and network access control configurations for data isolation.
- Verify network and communication controls:
 - HTTPS using TLS 1.2 or higher
 - VPN or segregated VLANs between internal components
 - Secure channels for API interactions with other subsystems (Case Mgmt., Prosecutor Office)

5. Audit and Logging Procedures

- Validate that the documentation covers:
 - Generation of comprehensive audit logs for all document-related activities (upload, modify, delete, share, print, sign).
 - Tamper protection, including immutable storage or cryptographic logging (T#004, T#014).
 - Log review processes and storage durations aligned with legal requirements.
 - Unique user identifiers and timestamps for non-repudiation.

6. Incident Response and Recovery Documentation

- Ensure there are documented, tested procedures for:
 - Responding to denial-of-service attacks via file upload flooding (T#006, T#013).
 - Malicious file upload detection, quarantine, and alerting (T#007, T#008, T#011).
 - Unauthorized access attempts and account lockout after failed logins (T#001, T#002, T#015).
- Confirm recovery documentation includes:
 - Disaster recovery time objectives (RTO) for document restoration (T#030).
 - Process for secure erasure of deleted files and backups (T#026).
 - Archival procedures based on retention policies and legal compliance (T#015).

7. Data Classification and Confidentiality Levels

- Review documentation for:
 - Proper classification schemes: Top Secret, Secret, Public (T#029)
 - Mapping of access rules to confidentiality level.
 - Enforcement of these levels during search, viewing, and export.

8. Integration Controls

- Verify that integrations with external systems (e.g., Case Management, National ID DB, Police) are:
 - Securely authenticated and authorized
 - Logged with appropriate metadata
 - Operating over TLS-protected or VPN channels
 - Implementing data validation at all exchange points

Test Cases

T#001 – Unauthorized Case Access (IDOR)

#	Test Case	Checked	Notes
1	Access document using valid case ID (authorized user)		
2	Access document using another user's case ID		
3	Tamper with URL to bypass RBAC		

T#002 – Phishing via Fake Login Page

#	Test Case	Checked	Notes
1	Attempt to simulate login from fake domain		
2	Intercept login request via HTTP		
3	Test login page for anti-phishing token		

T#003 – Document Content Tampering

#	Test Case	Checked	Notes
1	Upload signed document, then edit content		
2	Manually modify document content in DB		
3	Use forged hash to bypass verification		

T#004 – Audit Log Tampering

#	Test Case	Checked	Notes
1	Try to delete audit logs as admin		
2	Modify timestamps in logs		
3	Attempt to bypass logging during file delete		

T#005 – Confidential Document Leak

#	Test Case	Checked	Notes
1	Access sealed document without authorization		
2	Search with sensitive terms as public user		
3	Open document from deleted URL		

T#006 – DoS via Upload Flooding

#	Test Case	Checked	Notes
1	Upload 500 small files in 60 seconds		
2	Upload a single 2GB file		
3	Simulate multiple parallel uploads		

T#007 – Stored XSS in Metadata

#	Test Case	Checked	Notes
1	Upload file with <script> in title		
2	Add script to description field		
3	Execute payload through file preview		

T#008 – Arbitrary Code Execution via Malicious File

#	Test Case	Checked	Notes
1	Upload document with embedded macros		
2	Upload corrupted file to crash parser		
3	Test with known RCE payload document		

T#009 – Privilege Escalation

#	Test Case	Checked	Notes
1	Regular user accesses judge-only document		
2	Change user role in session cookie		
3	Submit document with elevated role		

T#010 – Metadata Forgery

#	Test Case	Checked	Notes
1	Modify author metadata post-upload		
2	Change upload timestamp using API		
3	Submit file with forged metadata		

T#011 – Malware in Uploaded Files

#	Test Case	Checked	Notes
1	Upload file with known malware signature		
2	Upload executable disguised as PDF		
3	Upload document with embedded script		

T#012 – Temporary Access Misuse

#	Test Case	Checked	Notes
1	Share document with time-limited access		
2	Try to access after expiry time		
3	Extend access without re-auth		

T#013 – Oversized File Upload

#	Test Case	Checked	Notes
1	Upload file larger than 20MB		
2	Upload large nested ZIP file (ZIP bomb)		
3	Monitor system performance during upload		

T#014 – Malicious Admin Retention Policy Change

#	Test Case	Checked	Notes
1	Admin changes retention to 1 day		
2	Delete document post-policy change		
3	Review audit logs for action trace		

T#015 – Misconfigured API Access

#	Test Case	Checked	Notes
1	Access document via unprotected API		
2	Bypass token by modifying header		
3	Call internal API without authentication		

Validation

T#001 – Unauthorized Case Access / IDOR Validation

- **PASS:** Request to unauthorized document returns HTTP 403 Forbidden or redirects to an access-denied page with no leakage of metadata or titles.
- **FAIL:** System returns HTTP 200 OK with any part of the document, title, or case number.

T#002 – Phishing via Fake Login Page

- **PASS:** Users are educated to detect phishing; the real login page uses HTTPS, and browser warning banners or anti-phishing tokens are present.
- **FAIL:** A user can be redirected or tricked into entering credentials into a fake login interface without system/browser detection.

T#003 – Document Content Tampering

- **PASS:** System detects tampering via failed signature or checksum and flags the document as invalid.
- **FAIL:** A tampered document is treated as valid and is accessible without any warning or alert.

T#004 – Audit Log Tampering

- **PASS:** Any attempt to delete or modify logs is either blocked or detected and logged elsewhere. Logs are read-only and immutable.
- **FAIL:** Logs can be deleted or altered from the application or database directly by users or admins without trace.

T#005 – Confidential Document Leak

- **PASS:** Unauthorized users attempting to access sealed or classified documents are denied access, and the system logs the attempt.
- **FAIL:** Users access sensitive documents (e.g., sealed rulings, personal data) without proper clearance or role.

T#006 – DoS via File Upload Flooding

- **PASS:** Upload throttling or rate-limiting mechanisms engage after multiple requests; server remains responsive.
- **FAIL:** System crashes, slows down, or drops connections during bulk/malicious uploads.

T#007 – Stored XSS in Document Metadata

- **PASS:** Script tags (<script>, onerror=, etc.) are escaped or displayed as plain text. No script is executed.
- **FAIL:** Payload is executed in another user's browser, evidenced by pop-up, redirect, or malicious action.

T#008 – Arbitrary Code Execution via Malicious File

- **PASS:** File is scanned, and malformed document is rejected. No execution on the server side occurs.
- **FAIL:** System attempts to process the document and crashes or opens a shell, indicating code execution.

T#009 – Privilege Escalation

- **PASS:** User actions (e.g., view, modify, delete) are checked server-side against RBAC. Unauthorized escalation attempts are denied.
- **FAIL:** A regular user performs privileged actions by modifying client-side values (e.g., URL manipulation).

T#010 – Metadata Forgery

- **PASS:** Metadata like timestamp, author, and case ID is signed or read-only after document upload.
- **FAIL:** A user can alter metadata via client-side manipulation or crafted API requests.

T#011 – Malware in Uploaded Documents

- **PASS:** File is scanned using an integrated antivirus engine; known threats are rejected and logged.
- **FAIL:** Malicious documents are uploaded and accessed by other users without scanning or alerts.

T#012 – Temporary Access Misuse

- **PASS:** Temporary sharing expires as scheduled; all changes are logged and traceable.
- **FAIL:** Shared access persists beyond the defined period or allows access to additional documents.

T#013 – Oversized File Upload (ZIP Bomb / Resource Drain)

- **PASS:** File is rejected with a clear error (e.g., "File too large"); server performance remains stable.
- **FAIL:** System slows, crashes, or enters an infinite loop while processing the oversized document.

T#014 – Malicious Admin Alters Retention Policies

- **PASS:** Changes to retention rules require multi-party approval and are logged with justification.
- **FAIL:** A single user can alter or delete documents by changing retention settings without checks or logs.

T#015 – Misconfigured API Exploit

- **PASS:** API endpoints enforce authentication and authorization. Unauthorized access returns 401 Unauthorized OR 403 Forbidden.
- **FAIL:** API responds with data (even partial) when called with manipulated IDs or missing tokens.

Backup

Why is Backup Critical for Document Management?

- In a system where documents are:
- Legally binding
- Sensitive and confidential
- Potentially irreplaceable
- Loss or corruption can lead to:
- Case delays
- Legal liabilities
- Trust loss in the system

Backup Operation: Analysis & Strategy

Objective

Create a secure, reliable, and consistent backup operation for documents and metadata to ensure business continuity, data recovery, and compliance.

What to Back Up?

Item	Description
Document Files	PDFs, images, and all uploaded evidence
Metadata	Associated document metadata (case ID, upload time, signer, file hash, etc.)
Database Entries	File paths, user associations, access logs
Audit Logs	For tracking document access/modifications
E-signature Certificates	For future validation during audits

Backup Methods

1. File System Backup

- For all stored documents (e.g., uploads/, evidence/)
- Daily incremental, weekly full
- Stored on separate storage drives or cloud object storage (e.g., AWS S3, Azure Blob)

2. Database Backup

- SQL or NoSQL depending on what stores the metadata
- Daily logical backups (SQL dumps) or binary backups (e.g., WAL in PostgreSQL)
- Include related tables: documents, users, cases, audit_logs

3. Cloud-based Backup (if allowed)

- Encrypted backups to AWS/Azure/Google with versioning and retention
- Ensures geographic redundancy
- Be mindful of data sovereignty laws (especially in Yemen)

Security for Backups

Control	Purpose
Encryption at rest	To secure backup files (AES-256 standard)
Encryption in transit	For backups transferred over network
Access control (RBAC)	Limit who can initiate and restore backups
Audit logging	Track access and changes to backups
Backup Integrity Checks	Use file hashes to detect corruption

Testing the Backups

You must regularly test backup recovery to avoid "backup in name only" issues.

Frequency: Monthly recovery drills

Scope: Random sample of files + full recovery simulation quarterly

Verify: Document integrity, metadata, access controls remain intact

Backup Scheduling Strategy

Frequency	Type	Scope
Hourly	Incremental	Metadata only
Daily	Incremental	Files + DB
Weekly	Full	All data + audit logs
Monthly	Archive	Encrypted full backup, retained 12 months

Backup Storage Strategy

Location	Purpose
Primary local storage	Fast recovery (e.g., same data center)
Off-site storage	Disaster recovery (e.g., secondary data center)
Cloud (if compliant)	Redundancy and geographic isolation

Backup Operations Workflow

- Trigger (Scheduled or manual)
- Lock or snapshot DB and file system (to avoid inconsistency)
- Backup execution
- Copy or snapshot files
- Export database
- Compress & encrypt backup
- Store in designated storage
- Update backup logs & metadata
- Notify admin/report status
- Run checksum or hash validation

Area	Tool/Option
File backup	rsync, tar, cloud sync tools (rclone)
Database	pg_dump, mysqldump, or native tools
Automation	cron jobs, Ansible, or Kubernetes CronJobs
Monitoring	Nagios, Prometheus, ELK for backup status
Encryption	GPG, OpenSSL, cloud KMS (key management services)

Final Notes

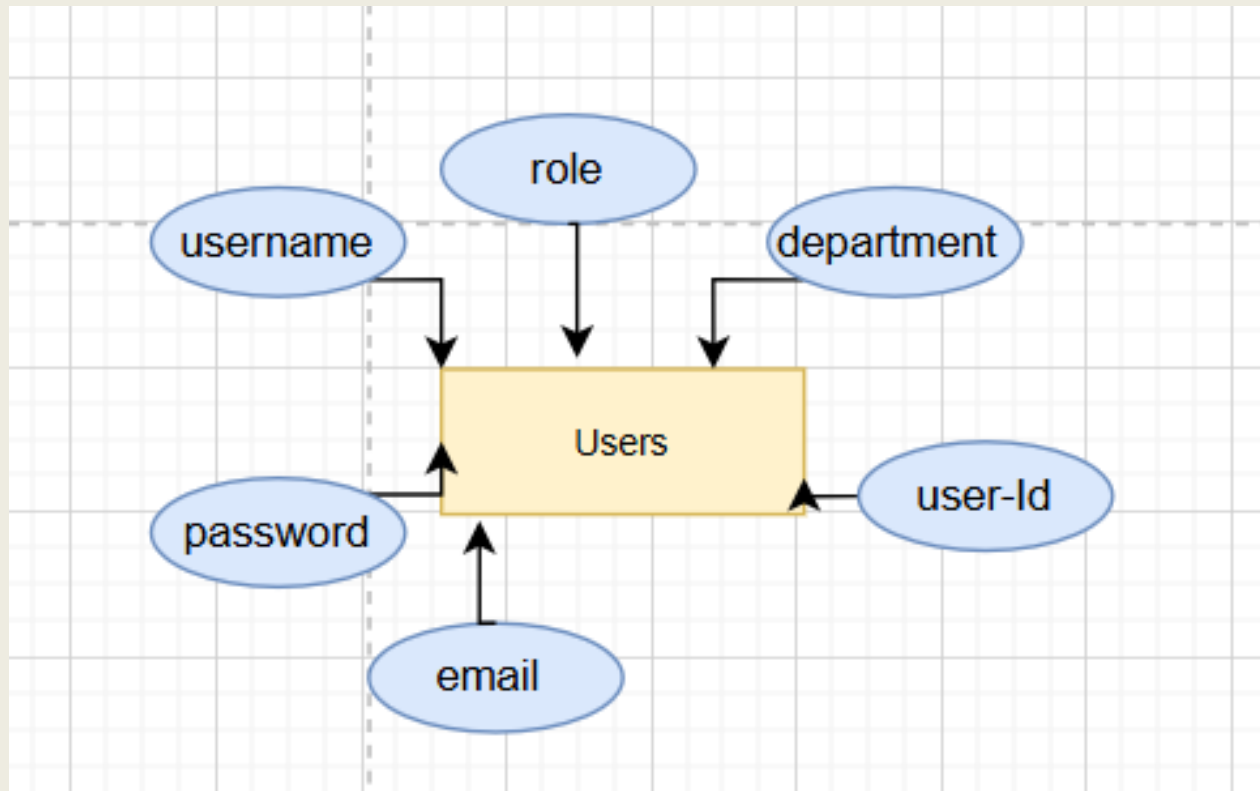
- Always store at least 3 backup copies:
- Primary storage
- Secondary location
- Cloud or secure vault
- Ensure backups are immutable (can't be altered)
- Include retention policy and GDPR/data protection compliance
- Document every step of the backup & recovery policy clearly

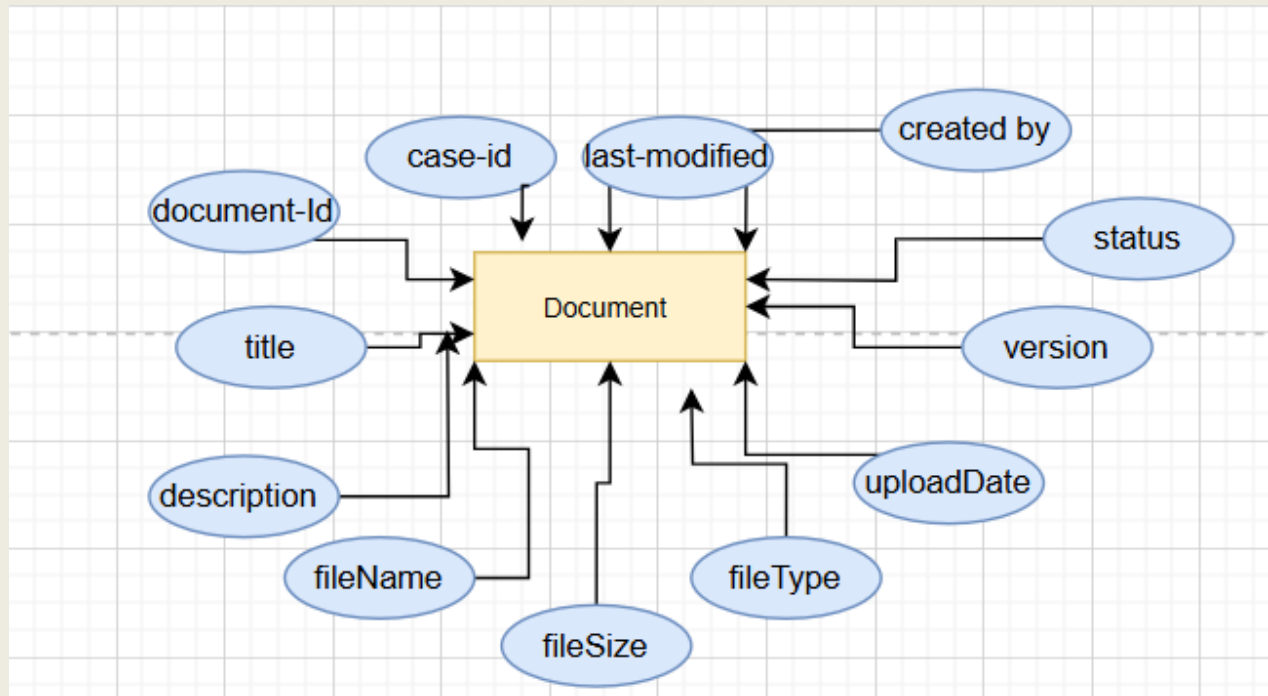
Want a Backup Policy Document?

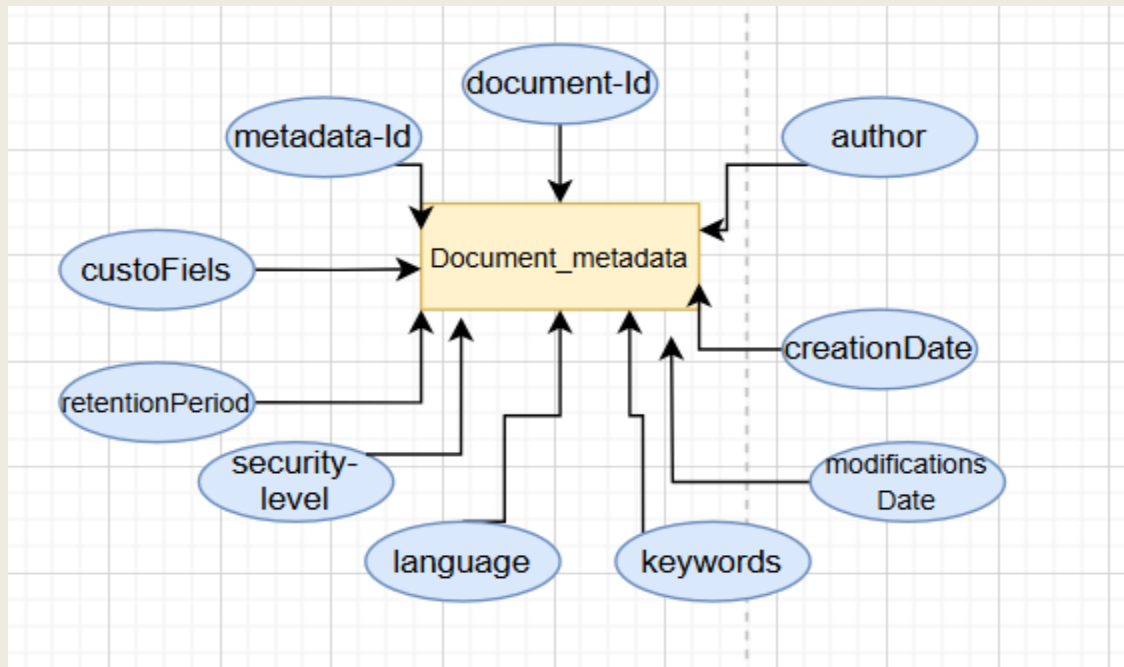
If you'd like, I can help you generate a formal Backup and Recovery Policy Document for the Document Management subsystem — including:

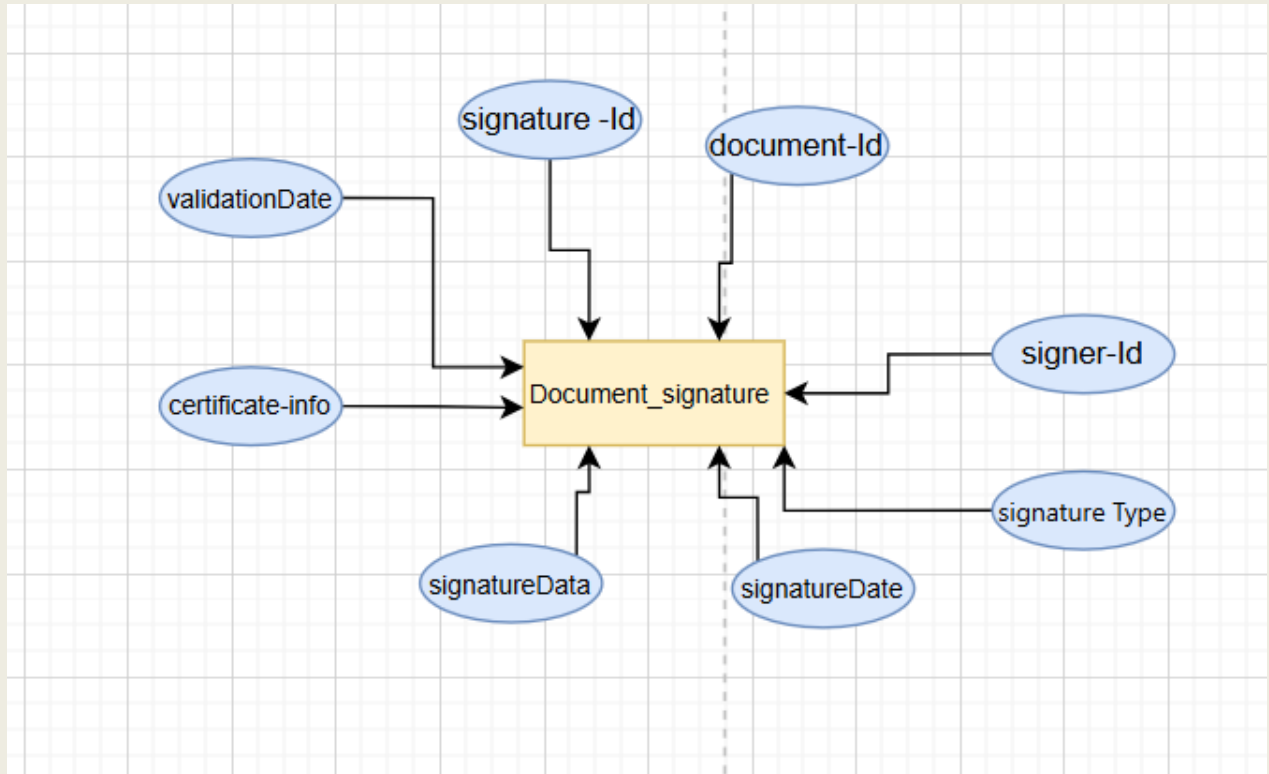
- Purpose
- Scope
- Backup types
- Roles/responsibilities
- Tools
- Schedules
- Testing protocols
- Compliance requirements

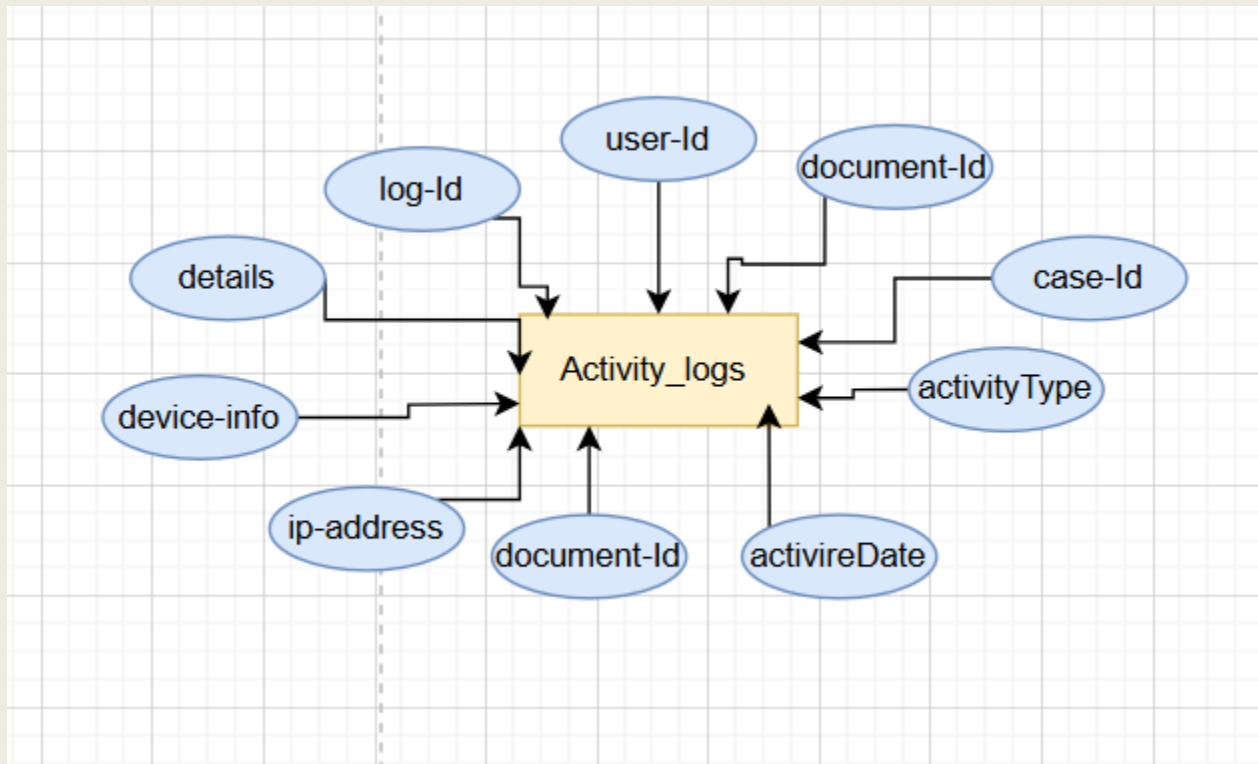
ER Diagrams

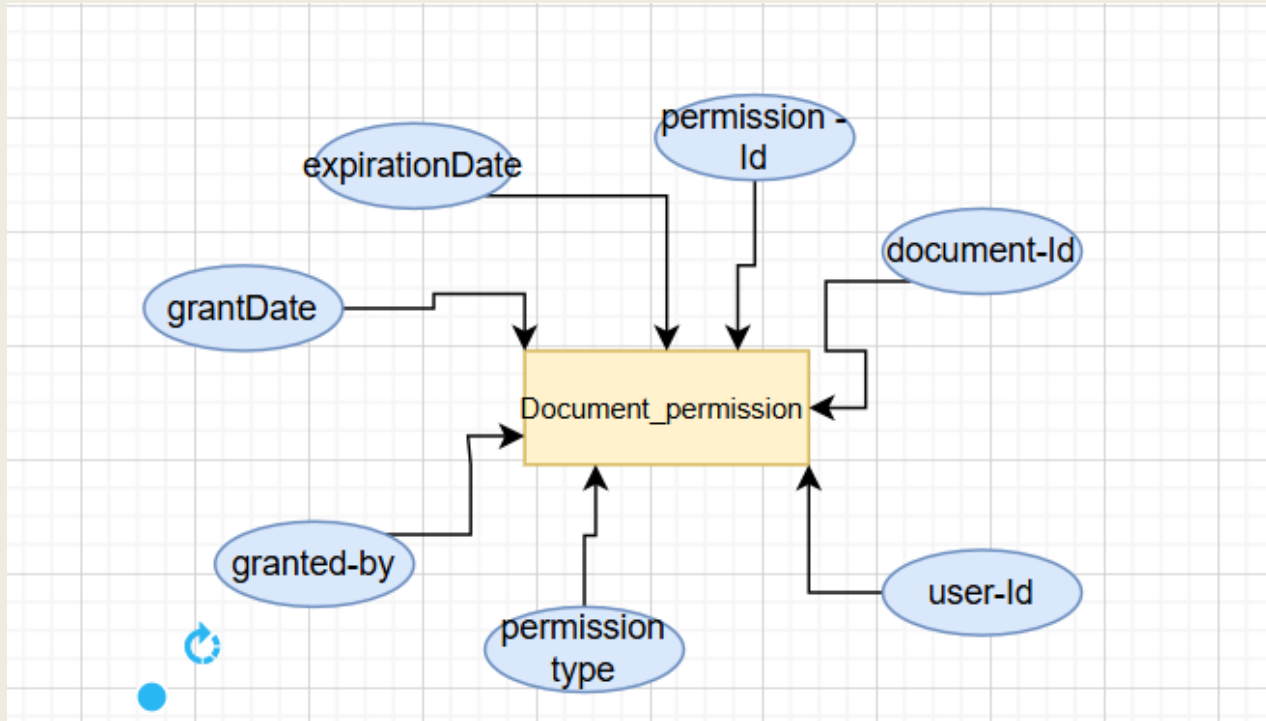


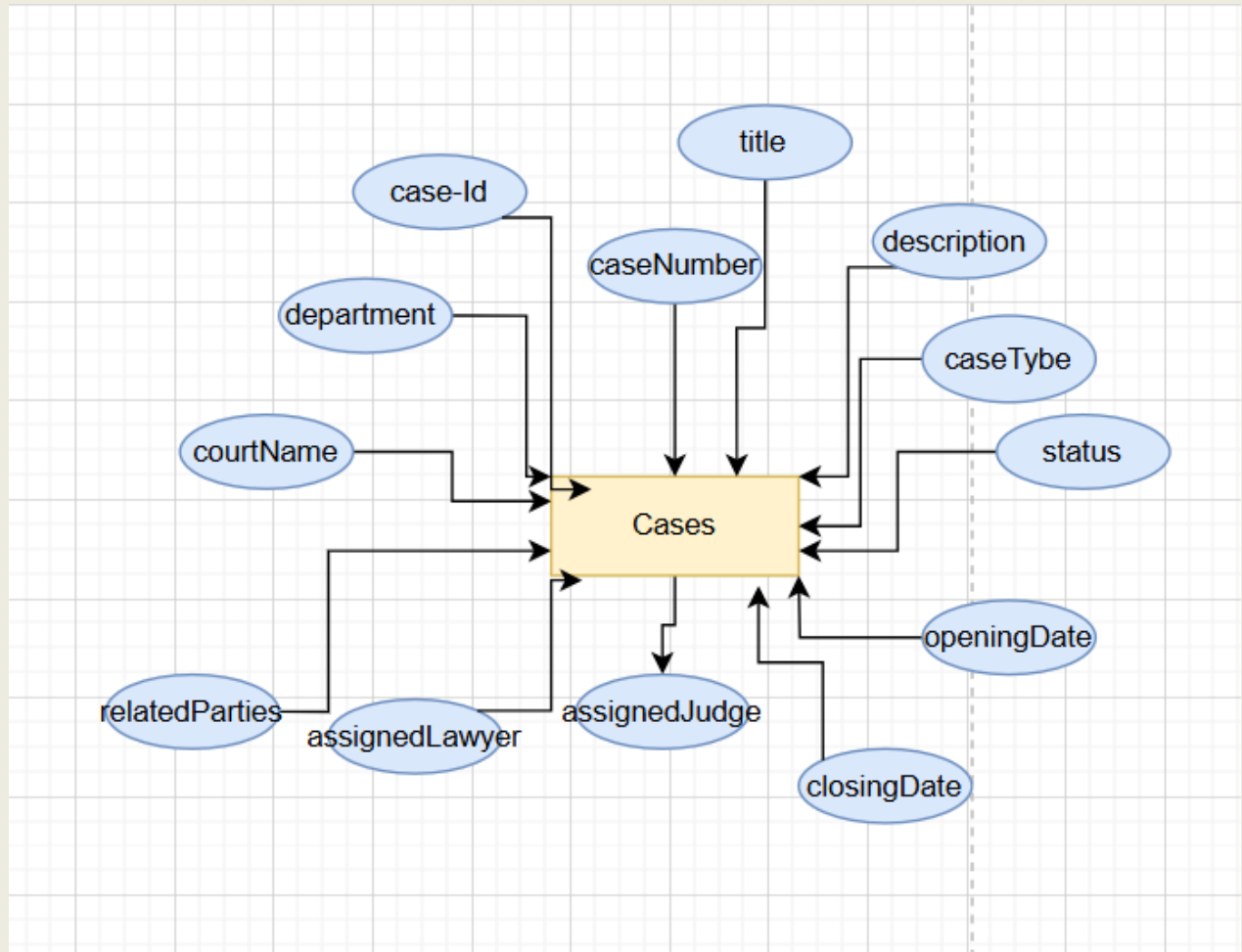


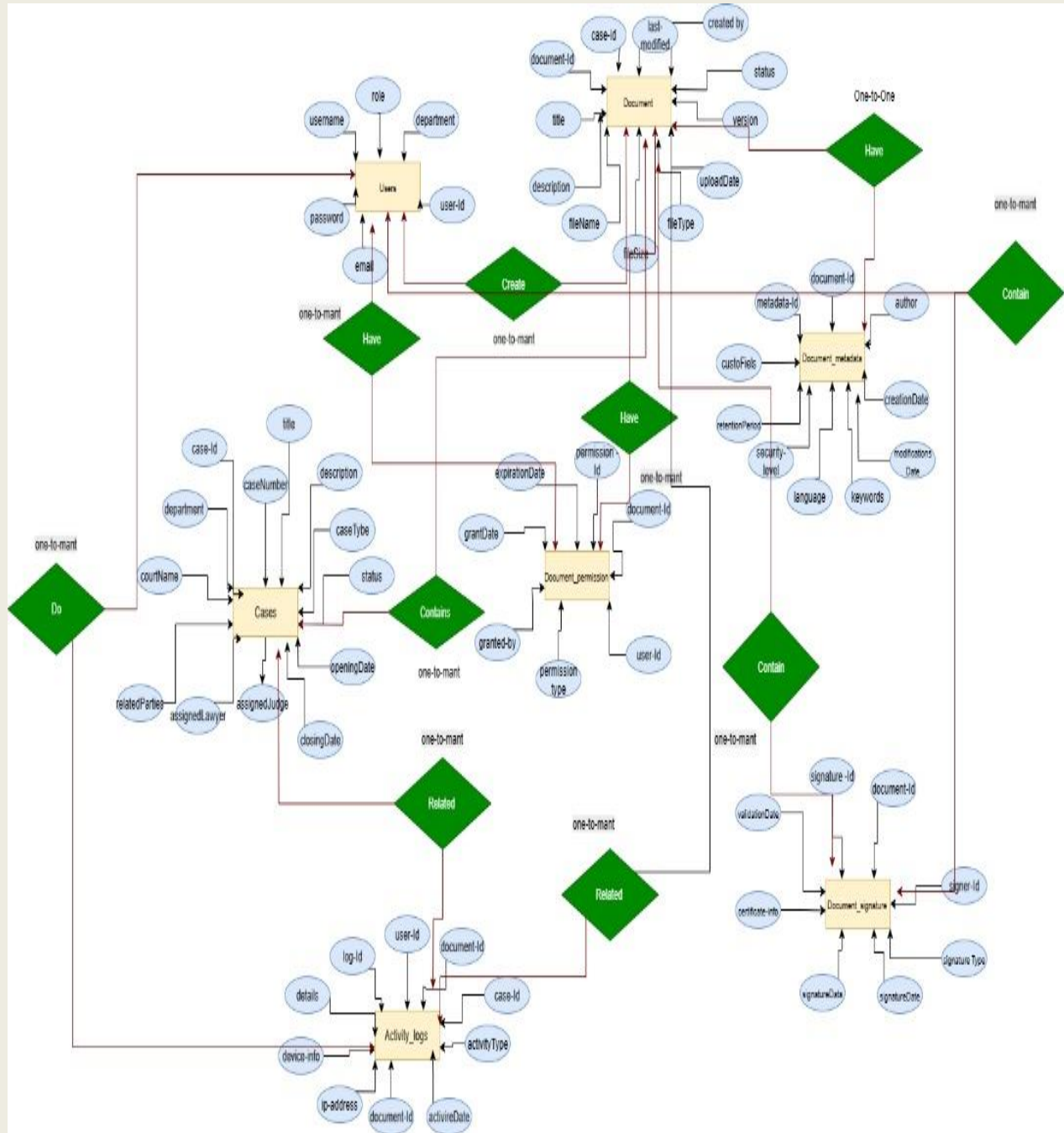




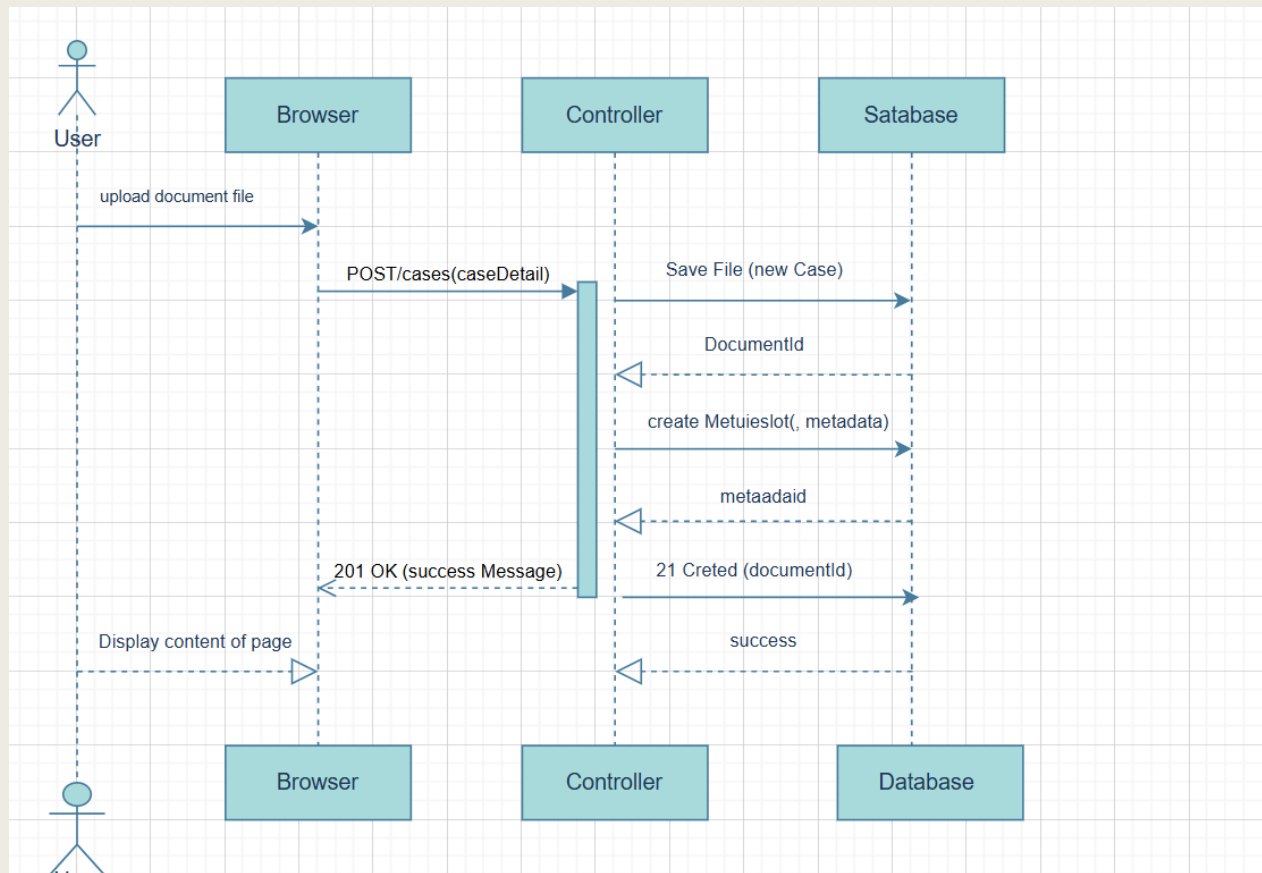




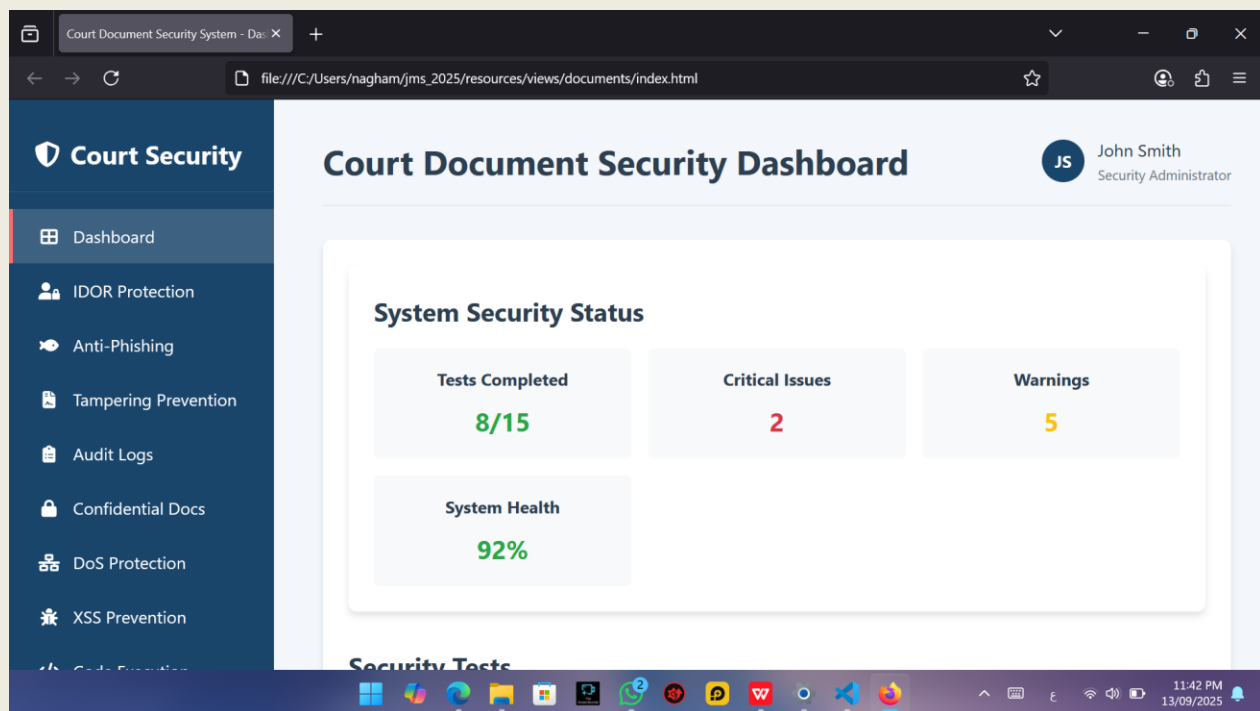


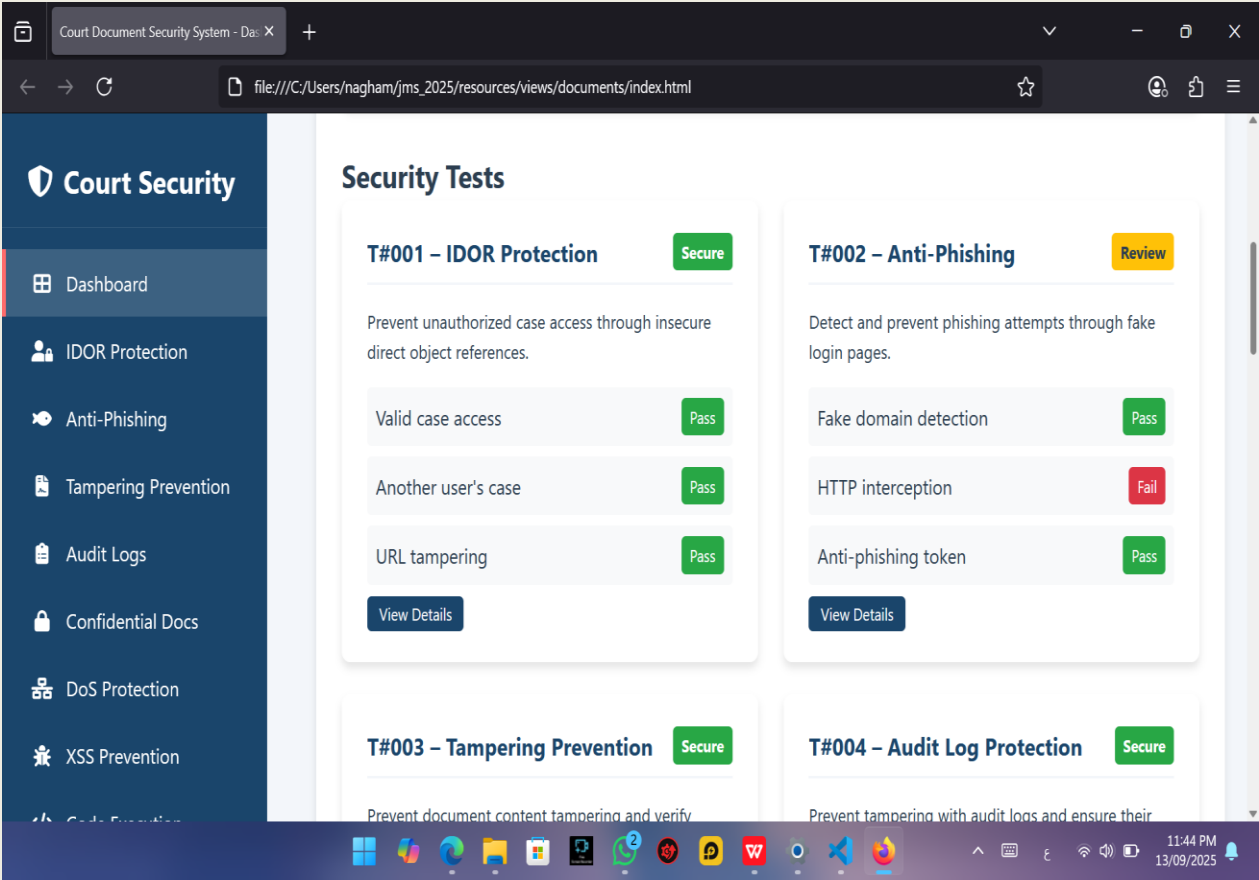


System Sequence Diagram:

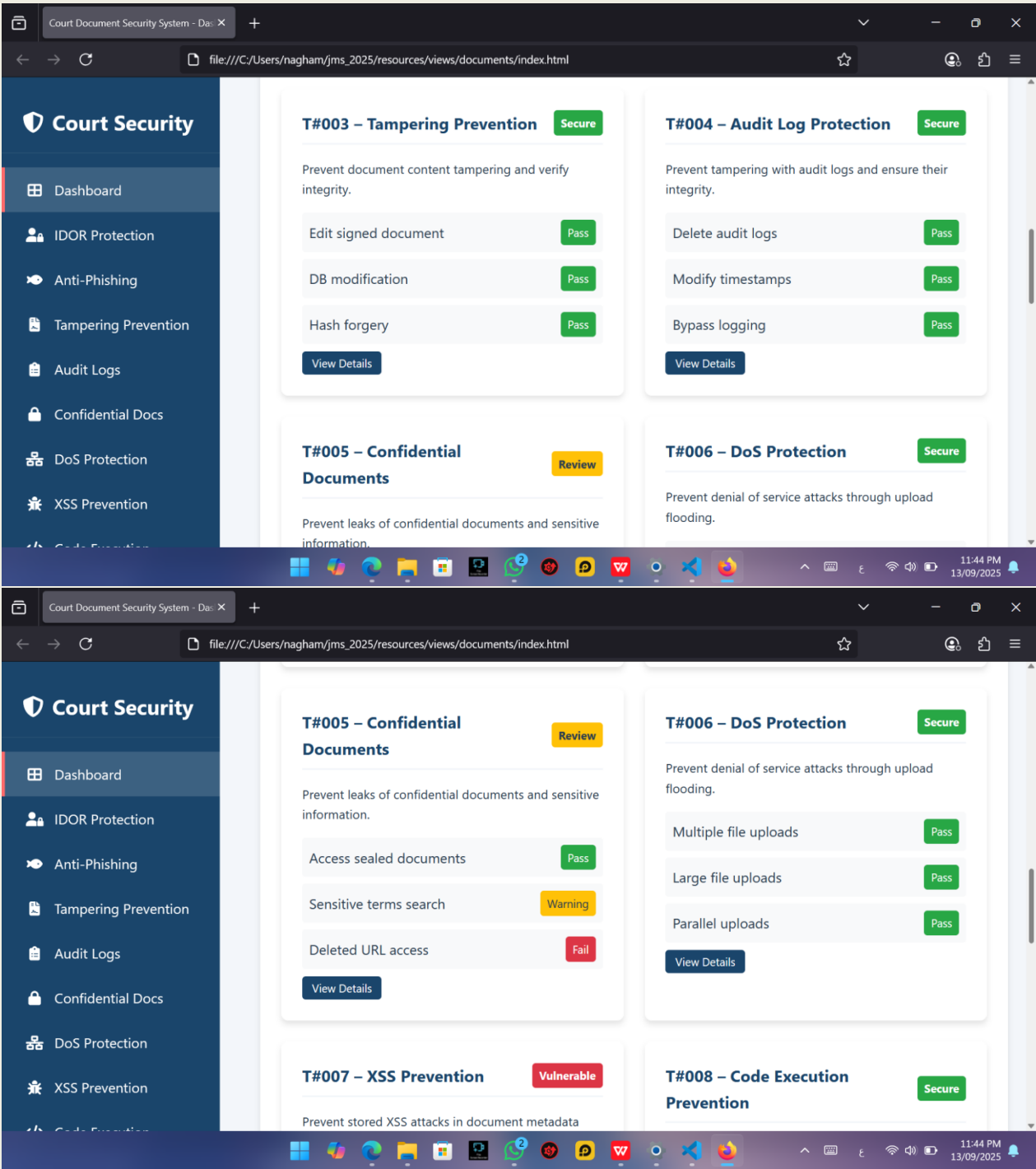


Document management Interfaces

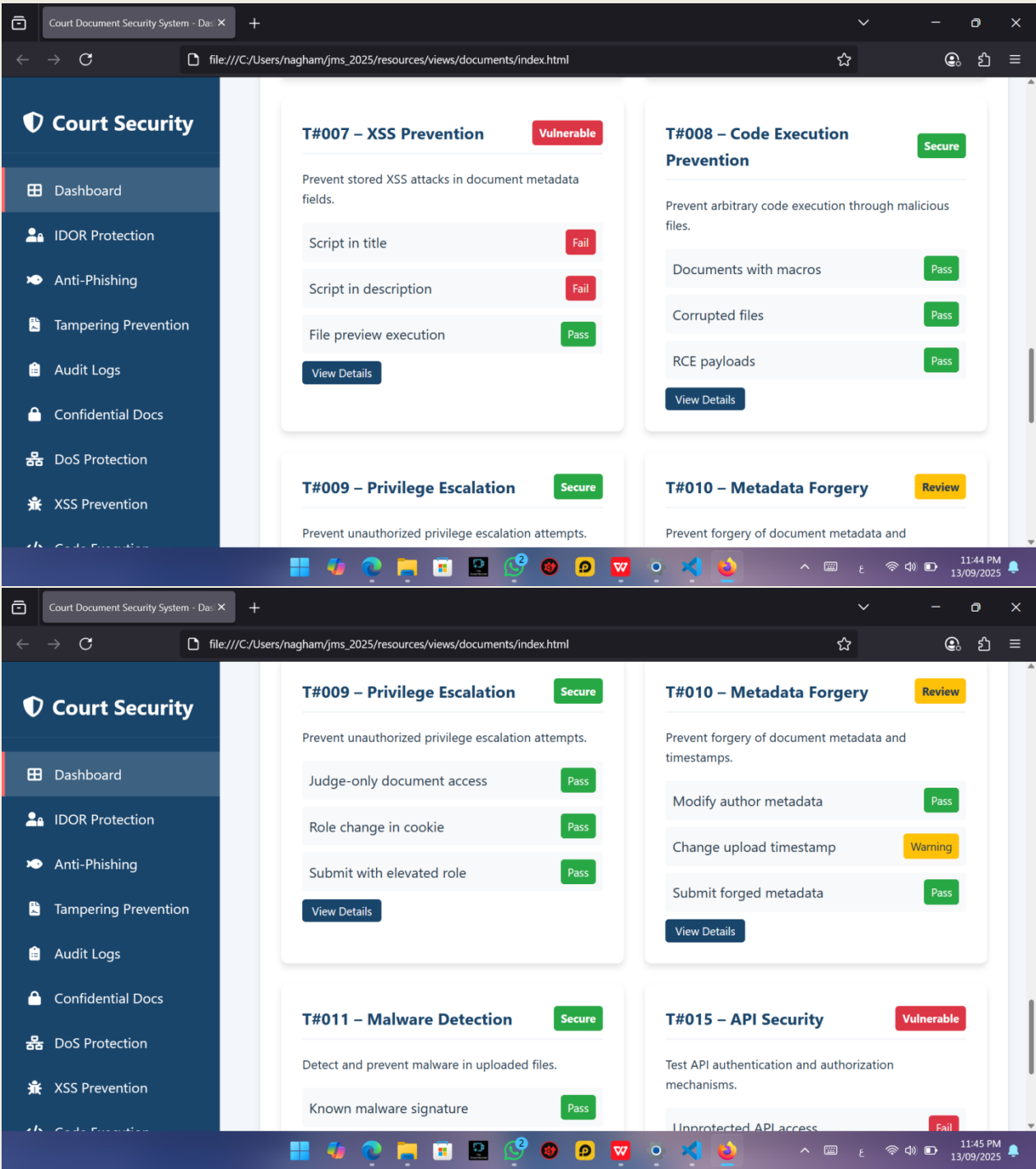




Secure Software Engineering



Secure Software Engineering



Secure Software Engineering

The image displays two screenshots of a web application interface for 'Court Security'. The interface features a dark blue sidebar with navigation links: Dashboard, IDOR Protection, Anti-Phishing, Tampering Prevention, Audit Logs, Confidential Docs, DoS Protection, XSS Prevention, and Code Execution. The main content area shows test cases for two different security scenarios.

Top Screenshot: T#001 – Unauthorized Case Access (IDOR)

- Test Case 1: Access document using valid case ID (authorized user)**
Verify that authorized users can access their own cases without issues.
[Run Test](#)
- Test Case 2: Access document using another user's case ID**
Attempt to access a case that belongs to another user to test authorization controls.
[Run Test](#)
- Test Case 3: Tamper with URL to bypass RBAC**

Bottom Screenshot: T#002 – Phishing via Fake Login Page

- Test Case 1: Attempt to simulate login from fake domain**
Test the system's ability to detect and block login attempts from unauthorized domains.
[Run Test](#)
- Test Case 2: Intercept login request via HTTP**
Test if the system prevents unencrypted login requests that could be intercepted.
[Run Test](#)
- Test Case 3: Test login page for anti-phishing token**

Both screenshots show a Windows taskbar at the bottom with various application icons and a system clock indicating 11:45 PM on 13/09/2025.

The image displays two screenshots of a web application interface for 'Court Security'. The interface features a dark blue sidebar with navigation links: Dashboard, IDOR Protection, Anti-Phishing, Tampering Prevention, Audit Logs, Confidential Docs, DoS Protection, XSS Prevention, and Code Execution. The main content area shows test cases for document content tampering and audit log tampering.

Top Screenshot: T#003 – Document Content Tampering

- Test Case 1: Upload signed document, then edit content**
Test if the system detects modifications to signed documents.
[Run Test](#)
- Test Case 2: Manually modify document content in DB**
Test if the system detects manual modifications to documents in the database.
[Run Test](#)
- Test Case 3: Use forged hash to bypass verification**

Bottom Screenshot: T#004 – Audit Log Tampering

- Test Case 1: Try to delete audit logs as admin**
Test if administrators can delete audit logs and if such actions are recorded.
[Run Test](#)
- Test Case 2: Modify timestamps in logs**
Test if the system prevents modification of timestamps in audit logs.
[Run Test](#)
- Test Case 3: Attempt to bypass logging during file delete**
Test if the system prevents bypassing audit logging during file deletion.

The screenshot displays the 'Court Security' web application interface. The left sidebar contains a navigation menu with the following items: Dashboard, IDOR Protection, Anti-Phishing, Tampering Prevention, Audit Logs, Confidential Docs (highlighted), DoS Protection, XSS Prevention, and Code Execution. The main content area shows two test case pages.

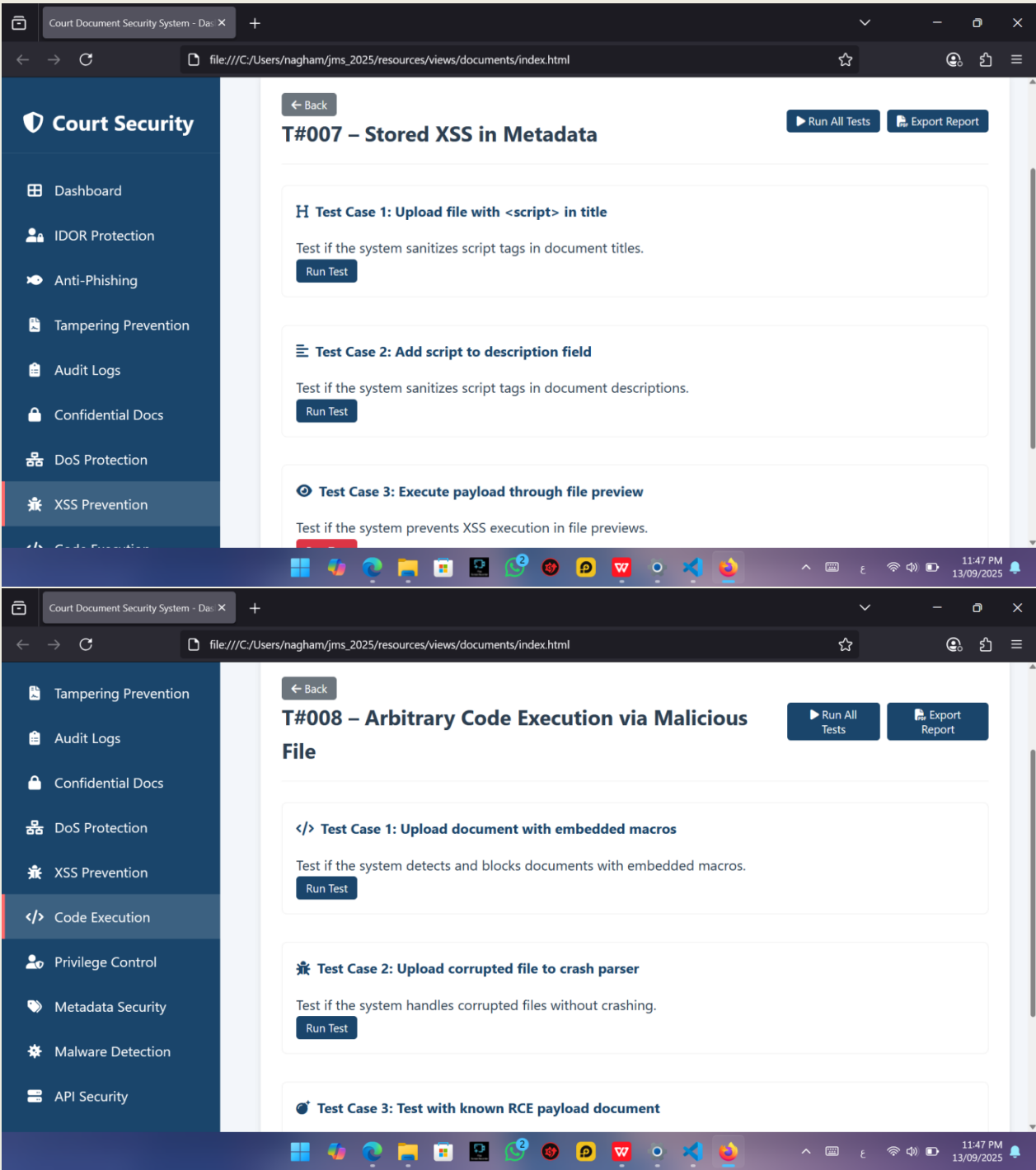
T#005 – Confidential Document Leak

- Test Case 1: Access sealed document without authorization**
Test if the system prevents unauthorized access to sealed documents.
[Run Test](#)
- Test Case 2: Search with sensitive terms as public user**
Test if the system prevents public users from searching for sensitive terms.
[Run Test](#)
- Test Case 3: Open document from deleted URL**

T#006 – DoS via Upload Flooding

- Test Case 1: Upload 500 small files in 60 seconds**
Test if the system can handle multiple file uploads without service degradation.
[Run Test](#)
- Test Case 2: Upload a single 2GB file**
Test if the system can handle large file uploads without service degradation.
[Run Test](#)
- Test Case 3: Simulate multiple parallel uploads**
Test if the system can handle parallel uploads without service degradation.
[Run Test](#)

The interface includes a top navigation bar with a 'Back' button and 'Run All Tests' and 'Export Report' buttons. The browser address bar shows the file path: file:///C:/Users/nagham/jms_2025/resources/views/documents/index.html. The system clock indicates 11:46 PM on 13/09/2025.



Secure Software Engineering

The screenshot displays a web application interface for the 'Court Document Security System'. The browser address bar shows the file path: `file:///C:/Users/nagham/jms_2025/resources/views/documents/index.html`. The left sidebar contains a menu with the following items: Tampering Prevention, Audit Logs, Confidential Docs, DoS Protection, XSS Prevention, Code Execution, Privilege Control, Metadata Security, Malware Detection, and API Security. The main content area is divided into two sections:

T#009 – Privilege Escalation

Buttons: [Run All Tests](#), [Export Report](#)

Test Case 1: Regular user accesses judge-only document
Test if the system prevents regular users from accessing judge-only documents.
[Run Test](#)

Test Case 2: Change user role in session cookie
Test if the system detects and prevents role changes in session cookies.
[Run Test](#)

Test Case 3: Submit document with elevated role
Test if the system prevents document submission with elevated roles.

T#010 – Metadata Forgery

Buttons: [Run All Tests](#), [Export Report](#)

Test Case 1: Modify author metadata post-upload
Test if the system prevents modification of author metadata after upload.
[Run Test](#)

Test Case 2: Change upload timestamp using API
Test if the system prevents modification of upload timestamps via API.
[Run Test](#)

Test Case 3: Submit file with forged metadata
Test if the system detects and prevents files with forged metadata.

The Windows taskbar at the bottom shows the time as 11:47 PM on 13/09/2025.

Secure Software Engineering

